
BSI Datenschutz++

Namespace Referenzen

Kreuzreferenzen zwischen Namespaces und Controls

Sascha Dierkes



Inhaltsverzeichnis

Namespace Einträge im BSI Grundschutz++	18
Inhalte	18
Disclaimer	18
Lizenz	20
Namespace: action_words	21
aktivieren	21
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	21
BSI/Grundschutz/Quellkataloge/Kernel	23
anhören	25
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	25
BSI/Grundschutz/Quellkataloge/Kernel	25
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	26
anweisen	26
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	26
BSI/Grundschutz/Quellkataloge/Kernel	26
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	27
BSI/Grundschutz/Quellkataloge/Risikomanagement	27
ausführen	27
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	27
BSI/Grundschutz/Quellkataloge/Kernel	28
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	29
authentifizieren	29
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	29
BSI/Grundschutz/Quellkataloge/Kernel	30
autorisieren	30
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	30
BSI/Grundschutz/Quellkataloge/Kernel	31
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	32
BSI/Grundschutz/Quellkataloge/Risikomanagement	32
blockieren	32
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	32
BSI/Grundschutz/Quellkataloge/Kernel	33
deaktivieren	33
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	33
BSI/Grundschutz/Quellkataloge/Kernel	34

dokumentieren	35
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	35
BSI/Grundschatz/Quellkataloge/Kernel	37
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	40
einschränken	40
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	40
BSI/Grundschatz/Quellkataloge/Kernel	42
festlegen	44
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	44
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	45
BSI/Grundschatz/Quellkataloge/Risikomanagement	45
informieren	46
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	46
BSI/Grundschatz/Quellkataloge/Kernel	46
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	47
installieren	47
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	47
BSI/Grundschatz/Quellkataloge/Kernel	49
löschen	50
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	50
BSI/Grundschatz/Quellkataloge/Kernel	51
platzieren	51
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	51
BSI/Grundschatz/Quellkataloge/Kernel	51
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	52
protokollieren	52
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	52
BSI/Grundschatz/Quellkataloge/Kernel	52
sensibilisieren	53
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	53
BSI/Grundschatz/Quellkataloge/Kernel	55
testen	56
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	56
BSI/Grundschatz/Quellkataloge/Kernel	57
überprüfen	58
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	58
BSI/Grundschatz/Quellkataloge/Kernel	60
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	62

überwachen	62
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	62
BSI/Grundschrift/Quellkataloge/Kernel	63
BSI/Grundschrift/Quellkataloge/Methodik-Grundschrift++	64
untersagen	64
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	64
BSI/Grundschrift/Quellkataloge/Kernel	65
verankern	66
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	66
BSI/Grundschrift/Quellkataloge/Kernel	69
BSI/Grundschrift/Quellkataloge/Methodik-Grundschrift++	72
BSI/Grundschrift/Quellkataloge/Risikomanagement	73
vereinbaren	73
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	73
BSI/Grundschrift/Quellkataloge/Kernel	75
verschlüsseln	76
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	76
BSI/Grundschrift/Quellkataloge/Kernel	77
zuweisen	77
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	77
BSI/Grundschrift/Quellkataloge/Kernel	78
BSI/Grundschrift/Quellkataloge/Methodik-Grundschrift++	79
Namespace: documentation_guidelines	80
???	80
Abnahmeprotokoll	80
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	80
BSI/Grundschrift/Quellkataloge/Kernel	80
Arbeitsanweisung	80
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	80
BSI/Grundschrift/Quellkataloge/Kernel	82
BSI/Grundschrift/Quellkataloge/Methodik-Grundschrift++	84
Arbeitsvertrag	84
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	84
BSI/Grundschrift/Quellkataloge/Kernel	84
Audit Log	84
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	84
BSI/Grundschrift/Quellkataloge/Kernel	85

Auditbericht	85
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	85
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	85
Auslagerungsregister	86
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	86
BSI/Grundschatz/Quellkataloge/Kernel	86
BC-Leitlinie	86
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	86
BSI/Grundschatz/Quellkataloge/Kernel	86
Behandlung von Sicherheitsvorfallen	86
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	86
BSI/Grundschatz/Quellkataloge/Kernel	87
Bereinigter Netzplan	87
Betriebshandbuch	88
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	88
BSI/Grundschatz/Quellkataloge/Kernel	88
Codehistorie	89
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	89
BSI/Grundschatz/Quellkataloge/Kernel	89
Compliance-Verpflichtungen	89
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	89
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	89
Datensicherungskonzept	89
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	89
BSI/Grundschatz/Quellkataloge/Kernel	90
Detektionskonzept	91
Entwicklungsdokumentation	91
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	91
BSI/Grundschatz/Quellkataloge/Kernel	91
Ergebnisprotokoll	91
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	91
BSI/Grundschatz/Quellkataloge/Kernel	92
Firewallregeln	92
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	92
BSI/Grundschatz/Quellkataloge/Kernel	92
Freigabeplan	93
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	93
BSI/Grundschatz/Quellkataloge/Kernel	93

Freigegebene Ausnahmegenehmigung	94
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	94
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	94
Gebäudedokumentation	94
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	94
BSI/Grundschutz/Quellkataloge/Kernel	95
Geschäftsprozesse	97
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	97
BSI/Grundschutz/Quellkataloge/Kernel	97
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	97
Geschäftsverteilungsplan	97
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	97
BSI/Grundschutz/Quellkataloge/Kernel	98
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	99
Informationssicherheitsleitlinie	99
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	99
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	99
Informationssicherheitsstrategie	99
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	99
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	99
Informationsverbund	99
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	99
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	99
Inventar Anwendungen	100
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	100
BSI/Grundschutz/Quellkataloge/Kernel	100
Inventar Berechtigungen	100
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	100
BSI/Grundschutz/Quellkataloge/Kernel	101
Inventar Berechtigungssysteme	101
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	101
BSI/Grundschutz/Quellkataloge/Kernel	101
Inventar Informationen	101
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	101
BSI/Grundschutz/Quellkataloge/Kernel	102
Inventar IT-Systeme	102
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	102
BSI/Grundschutz/Quellkataloge/Kernel	102

Inventar Standorte	102
ISMS-Regelwerk	102
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	102
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	102
IT-Betriebskonzept	102
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	102
BSI/Grundschatz/Quellkataloge/Kernel	105
Konfigurationshistorie	108
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	108
BSI/Grundschatz/Quellkataloge/Kernel	113
Leistungsbeschreibung	118
Leitlinie zur Informationssicherheit	118
Leitungsentscheidung	118
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	118
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	118
Liste der Hersteller und Dienstleister	118
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	118
BSI/Grundschatz/Quellkataloge/Kernel	119
Liste der Verpflichtungen	119
Managementbericht	119
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	119
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	119
Netzplan	120
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	120
BSI/Grundschatz/Quellkataloge/Kernel	120
Notfallhandbuch	121
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	121
BSI/Grundschatz/Quellkataloge/Kernel	121
Nutzungsbedingungen	122
Outsourcing-Strategie	122
Prozess Beschaffung	122
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	122
BSI/Grundschatz/Quellkataloge/Kernel	122
Prozess Dienstleistersteuerung	123
Prozess Gebäudemanagement	123
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	123
BSI/Grundschatz/Quellkataloge/Kernel	123

Prozess Identitäts- und Berechtigungsmanagement	123
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	123
BSI/Grundschutz/Quellkataloge/Kernel	124
Prozess Personalmanagement	124
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	124
BSI/Grundschutz/Quellkataloge/Kernel	124
Prüfplan	125
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	125
BSI/Grundschutz/Quellkataloge/Kernel	125
Realisierungsplan	125
Richtlinie zur Lenkung von Dokumenten und Aufzeichnungen	125
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	125
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	125
Richtlinie zur Risikoanalyse	125
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	125
BSI/Grundschutz/Quellkataloge/Risikomanagement	126
Risikobewertung	126
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	126
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	126
Schulungsplan	126
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	126
BSI/Grundschutz/Quellkataloge/Kernel	128
Schutzbedarfsfeststellung	130
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	130
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	130
Sicherheitsorganisation	130
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	130
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	130
Tätigkeits- & Rollenbeschreibung	130
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	130
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	130
Übersicht der Kommunikationspartner	130
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	130
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	131
Übungsplan	131
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	131
BSI/Grundschutz/Quellkataloge/Kernel	131

Umsetzungsplan	131
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	131
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	131
BSI/Grundschatz/Quellkataloge/Risikomanagement	132
Verfahrensbeschreibung	132
Verträge	132
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	132
BSI/Grundschatz/Quellkataloge/Kernel	132
Verzeichnis der Schwachstellen	132
Verzeichnis öffentlicher Schlüssel	132
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	132
BSI/Grundschatz/Quellkataloge/Kernel	132
Namespace: effort_level	134
Effort level: 0	134
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	134
BSI/Grundschatz/Quellkataloge/Kernel	138
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	140
BSI/Grundschatz/Quellkataloge/Risikomanagement	142
Effort level: 1	143
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	143
BSI/Grundschatz/Quellkataloge/Kernel	144
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	145
Effort level: 2	147
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	147
BSI/Grundschatz/Quellkataloge/Kernel	151
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	156
BSI/Grundschatz/Quellkataloge/Risikomanagement	156
Effort level: 3	157
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	157
BSI/Grundschatz/Quellkataloge/Kernel	164
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	171
Effort level: 4	172
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	172
BSI/Grundschatz/Quellkataloge/Kernel	176
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	180
Effort level: 5	181
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	181
BSI/Grundschatz/Quellkataloge/Kernel	186

Namespace: modal_verbs	192
KANN	192
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	192
BSI/Grundschatz/Quellkataloge/Kernel	198
MUSS	205
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	205
BSI/Grundschatz/Quellkataloge/Kernel	209
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	211
BSI/Grundschatz/Quellkataloge/Risikomanagement	213
SOLLTE	214
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	214
BSI/Grundschatz/Quellkataloge/Kernel	230
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	246
BSI/Grundschatz/Quellkataloge/Risikomanagement	246
Namespace: result	247
Alarmierung	247
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	247
BSI/Grundschatz/Quellkataloge/Kernel	247
Anforderung	247
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	247
BSI/Grundschatz/Quellkataloge/Kernel	247
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	248
Asset	248
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	248
BSI/Grundschatz/Quellkataloge/Kernel	249
Authentizität	249
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	249
BSI/Grundschatz/Quellkataloge/Kernel	249
Autorisierung	249
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	249
BSI/Grundschatz/Quellkataloge/Kernel	250
Biometrie	250
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	250
BSI/Grundschatz/Quellkataloge/Kernel	250
Elementare Gefährdungen	250
Gefährdung (englisch "applied threat")	250
Geschäftsprozess	250
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	250

BSI/Grundschatz/Quellkataloge/Kernel	251
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	251
BSI/Grundschatz/Quellkataloge/Risikomanagement	251
Institutionen	251
Integrität	251
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	251
BSI/Grundschatz/Quellkataloge/Kernel	251
Kompetenz	252
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	252
BSI/Grundschatz/Quellkataloge/Kernel	252
Korrekturmaßnahme	252
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	252
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	252
Maßnahme / Schutzmaßnahme	252
Praktik	252
Redundanz	252
Schwachstelle (englisch "vulnerability")	252
Sicherheitskritisches Ereignis	253
Sicherheitsrelevantes Ereignis	253
Sicherheitsvorfall	253
Verfügbarkeit	253
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	253
BSI/Grundschatz/Quellkataloge/Kernel	253
Vertraulichkeit	253
Zielobjekt	253
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	253
BSI/Grundschatz/Quellkataloge/Kernel	253
Zielobjektkategorie	254
Zugang	254
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	254
BSI/Grundschatz/Quellkataloge/Kernel	254
Zugangskonto	255
Zugriff	255
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	255
BSI/Grundschatz/Quellkataloge/Kernel	256
Zutritt	257
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	257
BSI/Grundschatz/Quellkataloge/Kernel	257

Namespace: tags	258
Advanced Persistent Threat (APT)	258
Advanced Persistent Threats (APT)	258
Archivierung	258
Auslandsreisen	258
Authentication and Authorization	258
Automatic Session Locking	258
Automatische Sicherheitsrichtlinie	258
BCM	258
Bring Your Own Device	259
Brute Force Angriffe	259
Brute-Force-Attacke	259
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	259
BSI/Grundschutz/Quellkataloge/Kernel	259
Change Management	259
Command & Control	259
Compliance Management	260
Compliance-Management	260
Credential Stuffing	260
Cryptography	260
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	260
BSI/Grundschutz/Quellkataloge/Kernel	260
Data Exfiltration	261
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	261
BSI/Grundschutz/Quellkataloge/Kernel	261
Data Leak	261
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	261
BSI/Grundschutz/Quellkataloge/Kernel	261
DDoS	261
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	261
BSI/Grundschutz/Quellkataloge/Kernel	261
Defense-in-depth	261
Denial of Service	262
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	262
BSI/Grundschutz/Quellkataloge/Kernel	262
Error Handling	262
Exit-Strategie	262
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	262

BSI/Grundschutz/Quellkataloge/Kernel	263
Failover	263
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	263
BSI/Grundschutz/Quellkataloge/Kernel	263
Führungsverantwortung	263
Hochverfügbarkeit	263
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	263
BSI/Grundschutz/Quellkataloge/Kernel	264
Honeypot	264
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	264
BSI/Grundschutz/Quellkataloge/Kernel	264
Insider Threat	264
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	264
BSI/Grundschutz/Quellkataloge/Kernel	264
Inspektion	264
Internet Exposure	264
Inventories	265
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	265
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	265
Kompetenzmanagement	265
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	265
BSI/Grundschutz/Quellkataloge/Kernel	265
Kontakt mit Behörden	265
Langzeitarchivierung	265
Lateral Movement	265
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	265
BSI/Grundschutz/Quellkataloge/Kernel	266
Lieferketten	266
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	266
BSI/Grundschutz/Quellkataloge/Kernel	266
Living off the land	266
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	266
BSI/Grundschutz/Quellkataloge/Kernel	266
MFA	266
Network Access Control	266
Password Policy	267
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	267
BSI/Grundschutz/Quellkataloge/Kernel	267

Pentest	267
Phishing	267
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	267
BSI/Grundschutz/Quellkataloge/Kernel	267
Physical Access Control	267
Privilege Escalation	268
Privilegierte Rechte	268
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	268
BSI/Grundschutz/Quellkataloge/Kernel	268
Produktbeschreibung	268
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	268
BSI/Grundschutz/Quellkataloge/Kernel	268
PSTN	269
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	269
BSI/Grundschutz/Quellkataloge/Kernel	269
Recon	269
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	269
BSI/Grundschutz/Quellkataloge/Kernel	269
Replay Attacks	269
Rogue Access Point	269
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	269
BSI/Grundschutz/Quellkataloge/Kernel	269
Secure Compiling Practices	270
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	270
BSI/Grundschutz/Quellkataloge/Kernel	270
Security by Default	270
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	270
BSI/Grundschutz/Quellkataloge/Kernel	270
Security by Design	270
Separation of Concerns	270
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	270
BSI/Grundschutz/Quellkataloge/Kernel	271
Session Hijacking	271
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	271
BSI/Grundschutz/Quellkataloge/Kernel	271
Shadow IT	271
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	271
BSI/Grundschutz/Quellkataloge/Kernel	272

Shared Responsibility Model	272
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	272
BSI/Grundschrift/Quellkataloge/Kernel	272
Shoulder Surfing	272
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	272
BSI/Grundschrift/Quellkataloge/Kernel	272
VPN	272
Zero Trust	273
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	273
BSI/Grundschrift/Quellkataloge/Kernel	273
Namespace: target_object_categories	274
Administrierende	274
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	274
BSI/Grundschrift/Quellkataloge/Kernel	274
Anwendungen	274
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	274
BSI/Grundschrift/Quellkataloge/Kernel	276
Cloud-Dienste	278
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	278
BSI/Grundschrift/Quellkataloge/Kernel	279
Dateiserver	279
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	279
BSI/Grundschrift/Quellkataloge/Kernel	279
Daten	279
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	279
BSI/Grundschrift/Quellkataloge/Kernel	280
Datenträgerarchiv	281
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	281
BSI/Grundschrift/Quellkataloge/Kernel	281
Dienstleistungen	281
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	281
BSI/Grundschrift/Quellkataloge/Kernel	282
DNS-Server	283
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	283
BSI/Grundschrift/Quellkataloge/Kernel	283
E-Mail	283
BSI/Grundschrift/Anwenderkatalog/Grundschrift++	283
BSI/Grundschrift/Quellkataloge/Kernel	284

Einkäufe	284
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	284
BSI/Grundschutz/Quellkataloge/Kernel	285
Endgeräte	287
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	287
BSI/Grundschutz/Quellkataloge/Kernel	287
Externe Netzanschlüsse	287
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	287
BSI/Grundschutz/Quellkataloge/Kernel	288
Fahrzeuge	288
Faxe	288
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	288
BSI/Grundschutz/Quellkataloge/Kernel	288
Führungskräfte	289
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	289
BSI/Grundschutz/Quellkataloge/Kernel	289
Gebäude	289
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	289
BSI/Grundschutz/Quellkataloge/Kernel	289
Hostsysteme	289
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	289
BSI/Grundschutz/Quellkataloge/Kernel	289
Informationen	290
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	290
BSI/Grundschutz/Quellkataloge/Kernel	290
Institutionsleitung	290
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	290
BSI/Grundschutz/Quellkataloge/Kernel	290
Interne Netzsegmente	290
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	290
BSI/Grundschutz/Quellkataloge/Kernel	290
Interpersonelle Kommunikation	291
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	291
BSI/Grundschutz/Quellkataloge/Kernel	291
IT-Produkte	291
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	291
BSI/Grundschutz/Quellkataloge/Kernel	291

IT-Systeme	292
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	292
BSI/Grundschatz/Quellkataloge/Kernel	294
Mitarbeitende	297
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	297
BSI/Grundschatz/Quellkataloge/Kernel	297
Mobiltelefone	297
Netze	298
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	298
BSI/Grundschatz/Quellkataloge/Kernel	299
Nutzende	300
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	300
BSI/Grundschatz/Quellkataloge/Kernel	301
Office-Anwendungen	302
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	302
BSI/Grundschatz/Quellkataloge/Kernel	302
Outsourcing	303
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	303
BSI/Grundschatz/Quellkataloge/Kernel	303
Räume	304
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	304
BSI/Grundschatz/Quellkataloge/Kernel	305
Räume für technische Infrastruktur	305
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	305
BSI/Grundschatz/Quellkataloge/Kernel	305
Serverräume	305
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	305
BSI/Grundschatz/Quellkataloge/Kernel	305
Standorte	306
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	306
BSI/Grundschatz/Quellkataloge/Kernel	307
TK-Anwendungen	308
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	308
BSI/Grundschatz/Quellkataloge/Kernel	309
Verzeichnisdienste	309
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	309
BSI/Grundschatz/Quellkataloge/Kernel	309

Virtualisierungslösungen	309
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	309
BSI/Grundschutz/Quellkataloge/Kernel	310
VK-Anwendungen	310
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	310
BSI/Grundschutz/Quellkataloge/Kernel	310
Webanwendungen	310
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	310
BSI/Grundschutz/Quellkataloge/Kernel	310
Webbrowser	311
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	311
BSI/Grundschutz/Quellkataloge/Kernel	311
Webserver	311
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	311
BSI/Grundschutz/Quellkataloge/Kernel	312
WLANS	312
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	312
BSI/Grundschutz/Quellkataloge/Kernel	312

Namespace Einträge im BSI Grundschutz++

Dieses Dokument stellt eine strukturierte Kreuzreferenz zwischen Namespace-Einträgen des BSI-Grundschutz++ und den zugehörigen Controls dar.

Ziel ist es, die in den Namespace-Definitionen verwendeten Begriffe, Klassifizierungen, Attribute und Merkmalsausprägungen transparent den Controls zuzuordnen, in denen diese referenziert oder verwendet werden. Dadurch entsteht ein systematischer Überblick über die Verwendung semantischer Konzepte innerhalb des Regelwerks.

Die Darstellung ist nach Namespaces gegliedert. Innerhalb jedes Namespace werden die vorhandenen Einträge aufgeführt und denjenigen Controls gegenübergestellt, in denen sie vorkommen.

Das Dokument wurde automatisiert erzeugt und bildet den zum Zeitpunkt der Generierung verfügbaren Datenbestand ab.

Inhalte

Aktuell werden folgende Namespaces mit Control Referenz gelistet:

- action_words
- documentation_guidelines
- effort_level
- modal_verbs
- result
- tags
- target_object_categories

Noch nicht unterstützt, für die Zukunft vorgesehen:

- practices
- security_level

Nicht unterstützt und nicht geplant:

- topics

Disclaimer

Dieses Dokument wurde automatisiert auf Basis der in einem Obsidian-Vault enthaltenen Inhalte generiert und ist nicht mit Obsidian verbunden.

Der verwendete Vault basiert auf dem Repository **BSI-Grundschutz++** und wurde seinerseits automatisiert aus den Inhalten des Projekts **Stand der Technik Bibliothek** des Bundesamts für Sicherheit in der Informationstechnik (BSI) erzeugt.

Die Zusammenstellung, Strukturierung und Ausgabe erfolgte mithilfe von Skripten, Plugins und Konvertierungswerkzeugen. Trotz sorgfältiger Erstellung kann nicht ausgeschlossen werden, dass Inhalte unvollständig, fehlerhaft, veraltet oder missverständlich dargestellt sind.

Maßgeblich sind ausschließlich die Originalinhalte des zugrunde liegenden Repositories:

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek>

sowie gegebenenfalls ergänzende Primärquellen, Normtexte, Richtlinien oder offizielle Veröffentlichungen.

Dieses Dokument dient ausschließlich der Information, Dokumentation und internen Unterstützung.

Es wird keine Gewähr für die Richtigkeit, Vollständigkeit, Aktualität oder Eignung für einen bestimmten Zweck übernommen. Jegliche Nutzung erfolgt auf eigene Verantwortung. Vor operativen, fachlichen, rechtlichen oder regulatorischen Entscheidungen sind die Inhalte eigenständig zu prüfen und bei Bedarf fachlich zu validieren.

Automatisch erzeugte Verknüpfungen, Klassifizierungen, Zuordnungen oder Auswertungen können vereinfachend sein und bedürfen gegebenenfalls einer manuellen Nachprüfung.

Lizenz

Dieses Dokument basiert auf Inhalten des **Bundesamts für Sicherheit in der Informationstechnik (BSI)** aus dem Projekt **Stand der Technik Bibliothek (Grundschutz++)**.

Originalquelle:

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek>

Verwendete Bestandteile:

- Anwendungskatalog (OSCAL)
- Namespace-Definitionen
- Quellkataloge

Die Originalinhalte stehen unter der Lizenz **Creative Commons Attribution-ShareAlike 4.0 International (CC BY-SA 4.0)**:

<https://creativecommons.org/licenses/by-sa/4.0/>

Dieses Dokument stellt eine bearbeitete bzw. transformierte Fassung dar und wird gemäß den Bedingungen der Lizenz ebenfalls unter **CC BY-SA 4.0** bereitgestellt.

Namespace: action_words

Definitionen zu Handlungs- bzw. Tätigkeitsverben

https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/raw/refs/heads/main/Dokumentation/namespaces/action_words.csv

aktivieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.3.3 SSIDs
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.16 Gruppenkonten - MFA
- BER.3.20 Dienstkonten
- BER.3.6 Single-Sign-On
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- DEV.3.4 Passwort-Hashing
- DEV.4.6 Compileroptionen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DLS.2.1 Mehr-Faktor-Authentifizierung
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.2 Warteraum
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.12.1 Eingabevalidierung
 - KONF.12.1.1 Zertifikatsprüfung
 - KONF.12.1.10 HTTP-Response-Header
 - KONF.12.1.7 Filtern schädlicher Webinhalte
 - KONF.12.1.9 Journaling
 - KONF.12.10 Cookie-Attribute

- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.7 Erweiterte Attribute
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.4 Caching
- KONF.15.3 Denial of Service
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.12 Konferenzmoderation
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung

- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.6.1 Mandantenfähigkeit
- KONF.7.1 Echtzeitscanner
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.8 Dual-Engine-Strategie
- KONF.8.2 Automatische Updates der Anwendung
- REA.2.2 Automatische Erstreaktion

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.3.3 SSIDs
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.16 Gruppenkonten - MFA
- BER.3.20 Dienstkonten
- BER.3.6 Single-Sign-On
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- DEV.3.4 Passwort-Hashing
- DEV.4.6 Compileroptionen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DLS.2.1 Mehr-Faktor-Authentifizierung
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.2 Warteraum
- KONF.11.3 Alternative Authentifizierung

- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.12.1 Eingabevalidierung
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.9 Journaling
- KONF.12.10 Cookie-Attribute
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.7 Erweiterte Attribute
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.4 Caching
- KONF.15.3 Denial of Service
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen

- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.12 Konferenzmoderation
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.6.1 Mandantenfähigkeit
- KONF.7.1 Echtzeitscanner
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.8 Dual-Engine-Strategie
- KONF.8.2 Automatische Updates der Anwendung
- REA.2.2 Automatische Erstreaktion

anhören

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.7.3 Anhörung Prozessbeteiligter
- DLS.3.4 Anhörung
- GC.7.1.2 Anhörung zuständiger Stellen

BSI/Grundschutz/Quellkataloge/Kernel

- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.7.3 Anhörung Prozessbeteiligter
- DLS.3.4 Anhörung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.7.1.2 Anhörung zuständiger Stellen

anweisen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.13 Lagerung physischer Assets
- ASST.5.6 Wartung durch Externe
- GEB.3.4 Berechtigungsmarkierung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.7.2 Verwahrung von Schlüsseln
- PERF.3.1.3 Auswahl des Auditteams
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- SENS.2.8 Melden von Ereignissen
- SENS.5.5 Löschfristen
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4 Begleitung Externer
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.3 Verwahrung außer Haus
- TEST.2.2 Folgenabschätzung

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.13 Lagerung physischer Assets
- ASST.5.6 Wartung durch Externe
- GEB.3.4 Berechtigungsmarkierung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock

- GEB.7.2 Verwahrung von Schlüsseln
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- SENS.2.8 Melden von Ereignissen
- SENS.5.5 Löschfristen
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4 Begleitung Externer
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.3 Verwahrung außer Haus
- TEST.2.2 Folgenabschätzung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.3.1.3 Auswahl des Auditteams

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.2 Einhaltung der BSI-Kriterien

ausführen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.5.2 Geregelte Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.4.1 Identitätsüberprüfung
- BER.6.9 Anlassbezogene Passwortwechsel
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.6.1.2 Automatische Alarmierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.2 Routinen zur Fehlerbehandlung
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.9.1.1 Externer Austausch zur Informationssicherheit
- KONF.10.3 Änderung von Default-Zugangsdaten

- KONF.2.3 Änderung von Default-Zugangsdaten
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- PERF.3.1.2 Planen von internen Audits
- PERF.3.1.4 Umfang von Audits
- PERF.4.1.2 Kommunikation an Stakeholder
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.3.7 Einarbeitung
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- REA.2.5 IT-Forensik
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

BSI/Grundschatz/Quellkataloge/Kernel

- ASST.5.2 Geregelter Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.4.1 Identitätsüberprüfung
- BER.6.9 Anlassbezogene Passwortwechsel
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.6.1.2 Automatische Alarmierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.2 Routinen zur Fehlerbehandlung

- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.2.3 Änderung von Default-Zugangsdaten
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.3.7 Einarbeitung
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- REA.2.5 IT-Forensik
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.9.1.1 Externer Austausch zur Informationssicherheit
- PERF.3.1.2 Planen von internen Audits
- PERF.3.1.4 Umfang von Audits
- PERF.4.1.2 Kommunikation an Stakeholder
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen

authentifizieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.1 Netzzugangskontrolle

- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.3 Authentifizierung von Routingprotokollen
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.1.2 Pre-Boot-Authentifizierung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.3 Authentifizierung von Routingprotokollen
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.1.2 Pre-Boot-Authentifizierung

autorisieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.2 Autorisiertes Routing
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten

- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.5.3 Autorisierung von Wartungen
- ASST.7.6 Autorisierung von Veräußerungen
- BER.7.7 Kein Transport privater Schlüssel
- BES.1.4.1 Freigabe der Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.3.1 Autorisierung kritischer Scans
- DEV.6.1 Freigabe nach Änderungen und Tests
- GC.10.2 Freigabe von Vorgehensweisen
- GC.6.1.4 Freigabe der Sicherheitsleitlinie
- GEB.1.3 Autorisierung von Standorten
- GEB.3.3.3 Besucheranmeldung
- GEB.4.2 Gesonderte Autorisierung
- KONF.4.2 DNS-Anbindung
- KONF.4.5 Zeitquellen
- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.5 Freigabe des Risikomanagements
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- UMS.5.1 Autorisierung von Ausnahmen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.2 Autorisiertes Routing
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.5.3 Autorisierung von Wartungen
- ASST.7.6 Autorisierung von Veräußerungen
- BER.7.7 Kein Transport privater Schlüssel

- BES.1.4.1 Freigabe der Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.3.1 Autorisierung kritischer Scans
- DEV.6.1 Freigabe nach Änderungen und Tests
- GEB.1.3 Autorisierung von Standorten
- GEB.3.3.3 Besucheranmeldung
- GEB.4.2 Gesonderte Autorisierung
- KONF.4.2 DNS-Anbindung
- KONF.4.5 Zeitquellen
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1 Unabhängigkeit der Autorisierung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.10.2 Freigabe von Vorgehensweisen
- GC.6.1.4 Freigabe der Sicherheitsleitlinie
- UMS.5.1 Autorisierung von Ausnahmen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.5 Freigabe des Risikomanagements

blockieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.9 Anmeldeversuchsgrenze am System

- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- DEV.3.1 Replay-Angriffe
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.13.1.1 SPAM-Filter
- KONF.14.5 Zeitüberschreitung von Netzverbindungen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- DEV.3.1 Replay-Angriffe
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.13.1.1 SPAM-Filter
- KONF.14.5 Zeitüberschreitung von Netzverbindungen

deaktivieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.2.5 Deaktivierung bei Weggang
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung

- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DLS.4.1.2 Berechtigungen deaktivieren
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.14 DNS-Falschinformationen
- KONF.12.6 Browser-Historie
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.5.2 Keine Mehrfachanmeldung

BSI/Grundschutz/Quellkataloge/Kernel

- BER.2.5 Deaktivierung bei Weggang
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DLS.4.1.2 Berechtigungen deaktivieren
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.14 DNS-Falschinformationen
- KONF.12.6 Browser-Historie
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.15.4 Überbuchung von virtualisierten Ressourcen

- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.5.2 Keine Mehrfachanmeldung

dokumentieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1.1 Dokumentation
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ASST.1.1.1 Dokumentation
- ASST.2.1 Inventar der Informationen
- ASST.2.2 Inventar der Systeme
- ASST.2.3 Inventar der Anwendungen
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.7 Dokumentation von Wartungen
- BER.1.1.1 Dokumentation
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.5.2 Begründung von Berechtigungen
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BES.1.1.1 Dokumentation
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.2.1 Erfassung des Bedarfes
- BES.2.1.1 Verwendungszweck
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.1.3 Systemvoraussetzungen

- BES.2.1.4 Kompatibilität
 - BES.2.1.4.1 Kompatibilität der Schnittstellen
 - BES.2.1.4.2 Kompatibilität der Netzanbindung
 - BES.2.1.4.3 Kompatibilität des Administrationsmodells
 - BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.7.4 Vollständigkeit der Unterlagen
 - BES.7.4.1 Beschreibung der Sicherheitsarchitektur
 - BES.7.4.10 Serviceprofil
 - BES.7.4.11 Dokumentierte Mandantentrennung
 - BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
 - BES.7.4.2 Beschreibung von Sicherheitsmechanismen
 - BES.7.4.3 Empfohlene Konfiguration
 - BES.7.4.4 Dokumentation der Komponenten
 - BES.7.4.4.1 Software Bill of Materials (SBOM)
 - BES.7.4.5 Netzverbindungen ab Werk
 - BES.7.4.6 Shared Responsibility
 - BES.7.4.7 Organisatorische Schnittstellen
 - BES.7.4.8 Technische Schnittstellen
 - BES.7.4.9 Auslagerungsregister
- DET.1.1.1 Dokumentation
- DET.3.4 Revisionssicherheit
- DET.3.5 Unbestreitbarkeit
- DET.5.2 Schwachstellenregister
- DET.6.1.3 Dokumentation von Ergebnissen
- DEV.1.1.1 Dokumentation
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten
- DLS.1.1.1 Dokumentation
- GC.7.1.3 Vertragliche Verpflichtungen
- GEB.1.1.1 Dokumentation
- GEB.1.5 Strukturpläne

- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.3.3.2 Dokumentation von Zutritten
- KONF.1.1.1 Dokumentation
- KONF.1.3 Management von Werkzeugen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.2.1 Grundkonfiguration für Systeme
- NOT.1.1.1 Dokumentation
- NOT.3.1 Wiederanlaufplan
- NOT.3.2 Geschäftsfortführungsplan
- NOT.4.1 Dokumentation der Quellen
- NOT.4.15 Vorgehen zur Wiederherstellung
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERF.5.1.9 Maßnahmenvorschläge
- PERS.1.1.1 Dokumentation
- PERS.3.4 Stellenbeschreibungen
- REA.1.1.1 Dokumentation
- REA.2.3 Dokumentation von Vorfällen
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.3.1.1 Quantitative Analyse
- SENS.1.1.1 Dokumentation
- STM.4.2 Dokumentation relevanter Assets
- TEST.1.1.1 Dokumentation
- TEST.2.2.2 Anpassung der Dokumentation
- TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.4.1.2 Dokumentation der Freigabe
- UMS.5.2 Dokumentation von Ausnahmen

- ARCH.1.1.1 Dokumentation
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ASST.1.1.1 Dokumentation
- ASST.2.1 Inventar der Informationen
- ASST.2.2 Inventar der Systeme
- ASST.2.3 Inventar der Anwendungen
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.7 Dokumentation von Wartungen
- BER.1.1.1 Dokumentation
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.5.2 Begründung von Berechtigungen
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BES.1.1.1 Dokumentation
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.2.1 Erfassung des Bedarfes
- BES.2.1.1 Verwendungszweck
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.4 Kompatibilität
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.4 Vertragsvorlage für Outsourcing

- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.10 Serviceprofil
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.1.1.1 Dokumentation
- DET.3.4 Revisionssicherheit
- DET.3.5 Unbestreitbarkeit
- DET.5.2 Schwachstellenregister
- DET.6.1.3 Dokumentation von Ergebnissen
- DEV.1.1.1 Dokumentation
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten
- DLS.1.1.1 Dokumentation
- GEB.1.1.1 Dokumentation
- GEB.1.5 Strukturpläne
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.3.3.2 Dokumentation von Zutritten
- KONF.1.1.1 Dokumentation
- KONF.1.3 Management von Werkzeugen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.2.1 Grundkonfiguration für Systeme
- NOT.1.1.1 Dokumentation
- NOT.3.1 Wiederanlaufplan
- NOT.3.2 Geschäftsfortführungsplan
- NOT.4.1 Dokumentation der Quellen
- NOT.4.15 Vorgehen zur Wiederherstellung

- PERS.1.1.1 Dokumentation
- PERS.3.4 Stellenbeschreibungen
- REA.1.1.1 Dokumentation
- REA.2.3 Dokumentation von Vorfällen
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.3.1.1 Quantitative Analyse
- SENS.1.1.1 Dokumentation
- TEST.1.1.1 Dokumentation
- TEST.2.2.2 Anpassung der Dokumentation
- TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.4.1.2 Dokumentation der Freigabe

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.7.1.3 Vertragliche Verpflichtungen
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERF.5.1.9 Maßnahmenvorschläge
- STM.4.2 Dokumentation relevanter Assets
- UMS.5.2 Dokumentation von Ausnahmen

einschränken

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
- ARCH.2.2.1 Externe Netzanschlüsse
- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.2 Gastnetz

- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.3 Mikrosegmentierung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- BER.2.2 Einschränkung
- BER.3.2 Einschränkung des Managements
- BER.5.1 Prinzip der geringsten Berechtigungen
- DET.3.2 Filterung nicht benötigter Inhalte
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.3 Cookies
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.15.1 Begrenzung des Speicherplatzes

- KONF.15.2 Begrenzung der Rechenleistung
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.15 Lokale Firewall
- KONF.7.9 Einschränkung der Installation
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.2 Begrenzung der Rechenleistung
- TEST.1.3 Einschränkung von Änderungen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.2 Gastnetz
 - ARCH.2.2.3 Segmentierung von Servern und Clients
 - ARCH.2.2.4 VoIP-Netz
 - ARCH.2.2.5 OT-Systeme
 - ARCH.2.2.8 Segmentierung von Test und Betrieb
 - ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.3 Mikrosegmentierung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen

- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- BER.2.2 Einschränkung
- BER.3.2 Einschränkung des Managements
- BER.5.1 Prinzip der geringsten Berechtigungen
- DET.3.2 Filterung nicht benötigter Inhalte
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.3 Cookies
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads

- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.15 Lokale Firewall
- KONF.7.9 Einschränkung der Installation
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.2 Begrenzung der Rechenleistung
- TEST.1.3 Einschränkung von Änderungen

festlegen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.10.1 Festlegung von Vorgehensweisen
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.8.1.3 Vermeidung von Interessenkonflikten
- GC.8.1.4 Festlegung einer Sicherheitsorganisation
- GC.8.1.5 Sicherstellung der Qualifikation
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.6.1.2 Schwachstellen
- PERF.6.1.3 Bedrohungen
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.4.1 Erfassung relevanter Assets

- UMS.2.1 Bewertung des Restrisikos
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.2 Festlegung von Umsetzungsfristen
- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.10.1 Festlegung von Vorgehensweisen
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.8.1.3 Vermeidung von Interessenkonflikten
- GC.8.1.4 Festlegung einer Sicherheitsorganisation
- GC.8.1.5 Sicherstellung der Qualifikation
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.6.1.2 Schwachstellen
- PERF.6.1.3 Bedrohungen
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.4.1 Erfassung relevanter Assets
- UMS.2.1 Bewertung des Restrisikos
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.2 Festlegung von Umsetzungsfristen
- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.4 Risikoappetit

informieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1.3 Bekanntgabe
- ASST.1.1.3 Bekanntgabe
- ASST.5.5 Wartungsfenster
- BER.1.1.3 Bekanntgabe
- BES.1.1.3 Bekanntgabe
- DET.1.1.3 Bekanntgabe
- DEV.1.1.3 Bekanntgabe
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DLS.1.1.3 Bekanntgabe
- GEB.1.1.3 Bekanntgabe
- KONF.1.1.3 Bekanntgabe
- NOT.1.1.3 Bekanntgabe
- PERF.5.2 Bericht an die Institutionsleitung
- PERS.1.1.3 Bekanntgabe
- REA.1.1.3 Bekanntgabe
- REA.2.6.2.1 Information zuständiger Behörden
- SENS.1.1.3 Bekanntgabe
- SENS.2.2 Meldewege
- TEST.1.1.3 Bekanntgabe
- TEST.5.1 Information betroffener Kreise

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1.3 Bekanntgabe
- ASST.1.1.3 Bekanntgabe
- ASST.5.5 Wartungsfenster
- BER.1.1.3 Bekanntgabe
- BES.1.1.3 Bekanntgabe
- DET.1.1.3 Bekanntgabe
- DEV.1.1.3 Bekanntgabe
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung

- DLS.1.1.3 Bekanntgabe
- GEB.1.1.3 Bekanntgabe
- KONF.1.1.3 Bekanntgabe
- NOT.1.1.3 Bekanntgabe
- PERS.1.1.3 Bekanntgabe
- REA.1.1.3 Bekanntgabe
- REA.2.6.2.1 Information zuständiger Behörden
- SENS.1.1.3 Bekanntgabe
- SENS.2.2 Meldewege
- TEST.1.1.3 Bekanntgabe
- TEST.5.1 Information betroffener Kreise

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.5.2 Bericht an die Institutionsleitung

installieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.12 Sprungserver
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.13 Produktdiversität
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.1 Dimensionierung der Netzanbindung
- ARCH.9.4 Content Delivery Network
- ASST.7.5 Vernichtungseinrichtungen
- BER.3.1 Zentrales Management
- BER.3.21 Notfallzugang
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.6.1 Passwortmanager
- DET.2.1.2 Meldeformulare
- DET.4.10 Host-basierte Köder

- DET.4.11.2 Netzwerk-Honeypots
- DET.6.2.2 Datenträgerschleuse
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- GEB.10.1 Klimatisierung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.1 Installation von Perimetern
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.5 Einbruchhemmung
- GEB.4.1 Einrichtung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.3.4 Physischer Diebstahlschutz
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.2.1.3 Stabsraum

- NOT.4.11 Datenträgerarchiv
- NOT.4.9 Speichermedien
- TEST.3.1.4 Testumgebung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.12 Sprungserver
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.13 Produktdiversität
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.1 Dimensionierung der Netzanbindung
- ARCH.9.4 Content Delivery Network
- ASST.7.5 Vernichtungseinrichtungen
- BER.3.1 Zentrales Management
- BER.3.21 Notfallzugang
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.6.1 Passwortmanager
- DET.2.1.2 Meldeformulare
- DET.4.10 Host-basierte Köder
- DET.4.11.2 Netzwerk-Honeypots
- DET.6.2.2 Datenträgerschleuse
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- GEB.10.1 Klimatisierung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.5 Ableitfähiger Fußbodenbelag

- GEB.2.1 Installation von Perimetern
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.5 Einbruchhemmung
- GEB.4.1 Einrichtung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.3.4 Physischer Diebstahlschutz
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.2.1.3 Stabsraum
- NOT.4.11 Datenträgerarchiv
- NOT.4.9 Speichermedien
- TEST.3.1.4 Testumgebung

löschen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.7.3 Regelmäßiges Löschen oder Vernichten
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.7 Beschriftungen entfernen
- BER.2.6 Löschen nach Fristablauf
- BER.3.13 Zugang löschen nach Fristablauf

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.7.3 Geregeltes Löschen oder Vernichten
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.7 Beschriftungen entfernen
- BER.2.6 Löschen nach Fristablauf
- BER.3.13 Zugang löschen nach Fristablauf

platzieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.2 Dedizierte Hardware
- ARCH.7.3 Entwicklungs- und Testumgebungen
- GEB.1.4 Exponierte Bereiche
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.8.1.1 Archiv
- NOT.4.10 Getrennte Aufbewahrung
- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.2 Dedizierte Hardware
- ARCH.7.3 Entwicklungs- und Testumgebungen
- GEB.1.4 Exponierte Bereiche
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.8.1.1 Archiv
- NOT.4.10 Getrennte Aufbewahrung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes

protokollieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.4.4 Nachweis des Zugangs
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.3.3 Protokollierung von Änderungen
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
 - DET.3.1.1 Authentifizierungen
 - DET.3.1.10 Nutzungsstatistik
 - DET.3.1.11 Anwendungsspezifische Ereignisse
 - DET.3.1.12 Datenverarbeitungen
 - DET.3.1.13 Integration von Cloud-Diensten
 - DET.3.1.2 Ausgeführte Kommandozeilenbefehle
 - DET.3.1.3 Anbindung von Peripheriegeräten
 - DET.3.1.4 Systemfehler
 - DET.3.1.5 Störungen der Netzerreichbarkeit
 - DET.3.1.6 Systemspezifische Ereignisse
 - DET.3.1.7 Was, Wann, Wo
 - DET.3.1.8 Privilegierte Ereignisse
 - DET.3.1.9 Fehler der Anwendung
- DET.6.1.1 Automatisierte Feststellung
- DEV.4.10 Protokollierung von Codeänderungen
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- TEST.2.1 Versionshistorie

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.4.4 Nachweis des Zugangs
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.3.3 Protokollierung von Änderungen
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
 - DET.3.1.1 Authentifizierungen

- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.6.1.1 Automatisierte Feststellung
- DEV.4.10 Protokollierung von Codeänderungen
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- TEST.2.1 Versionshistorie

sensibilisieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen

- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.6 Papiervernichtung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.5 Verwahrung Intern
- SENS.8.7 Verwendung von Brandschuttmitteln

- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.6 Papiervernichtung

- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.5 Verwahrung Intern
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise

testen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.3.1 Netzabdeckung
- ASST.3.6 Verifikation

- ASST.6.3 Konformitätsprüfung
- ASST.7.4 Wiederherstelltest
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.3.3 Historische Analyse
- DET.6.2.1 Dynamische Sandbox-Analyse
- DEV.2.6.1 Eingabevalidierung
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DLS.4.1.1 Unabhängigkeit
- GEB.1.3.1 Abnahme von Standorten
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- TEST.3.1 Sicherheitstest
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.2 Integritätstest
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.1.1.1 Staging
- TEST.5.4 Persistenz

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.3.1 Netzabdeckung
- ASST.3.6 Verifikation
- ASST.6.3 Konformitätsprüfung
- ASST.7.4 Wiederherstelltest

- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.3.3 Historische Analyse
- DET.6.2.1 Dynamische Sandbox-Analyse
- DEV.2.6.1 Eingabevalidierung
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DLS.4.1.1 Unabhängigkeit
- GEB.1.3.1 Abnahme von Standorten
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- TEST.3.1 Sicherheitstest
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.2 Integritätstest
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.1.1.1 Staging
- TEST.5.4 Persistenz

überprüfen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.2 Regelmäßige Überprüfung
- ARCH.2.6 Topologieüberwachung
- ASST.1.2 Regelmäßige Überprüfung
- ASST.2.3.2.1 Software Discovery

- BER.1.2 Regelmäßige Überprüfung
- BER.2.3 Stammdatenprüfung
- BER.5.3 Überprüfung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.7.14 Schlüssel vor Ablauf prüfen
- BES.1.2 Regelmäßige Überprüfung
- DET.1.2 Regelmäßige Überprüfung
- DET.3.3 Speicherkapazität
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.18 Öffentliche Blocklisten
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.6 Threat Hunting
- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8 Bedrohungsanalyse
- DET.5.8.1 Auswertung öffentlicher Quellen
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.2 Regelmäßige Überprüfung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.6 Portabilität
- GEB.1.2 Regelmäßige Überprüfung
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.4.1 Niederohmigkeit
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.7.3 Schlüsselaudit
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.2 Lasttest
- KONF.1.2 Regelmäßige Überprüfung
- KONF.10.5 Überprüfung der Konfiguration
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports

- KONF.2.5 Überprüfung der Konfiguration
- KONF.7.7 Regelmäßiger Funktionstest
- NOT.1.2 Regelmäßige Überprüfung
- NOT.2.1.4 Stabsübung
- NOT.3.4 Funktionstest
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.17 Anwendungstest
- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- PERF.5.1 Eignungsprüfung
- PERF.7.1 Aktualität der Anforderungen
- PERS.1.2 Regelmäßige Überprüfung
- PERS.4.1 Qualifikationsbedarf
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- REA.1.2 Regelmäßige Überprüfung
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.3.1 Verbesserung durch Erkenntnisse
- SENS.1.2 Erfolgsmessung
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- TEST.1.2 Regelmäßige Überprüfung
- TEST.3.2 Testabdeckung
- TEST.5.5 Rückblick
- UMS.1.1 Ermittlung des Umsetzungsstatus
- VRB.2.2 Anpassung des ISMS
- VRB.6.1 Wirksamkeitsprüfung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.2 Regelmäßige Überprüfung
- ARCH.2.6 Topologieüberwachung
- ASST.1.2 Regelmäßige Überprüfung
- ASST.2.3.2.1 Software Discovery
- BER.1.2 Regelmäßige Überprüfung
- BER.2.3 Stammdatenprüfung

- BER.5.3 Überprüfung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.7.14 Schlüssel vor Ablauf prüfen
- BES.1.2 Regelmäßige Überprüfung
- DET.1.2 Regelmäßige Überprüfung
- DET.3.3 Speicherkapazität
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.18 Öffentliche Blocklisten
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.6 Threat Hunting
- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8 Bedrohungsanalyse
- DET.5.8.1 Auswertung öffentlicher Quellen
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.2 Regelmäßige Überprüfung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.6 Portabilität
- GEB.1.2 Regelmäßige Überprüfung
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.4.1 Niederohmigkeit
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.7.3 Schlüsselaudit
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.2 Lasttest
- KONF.1.2 Regelmäßige Überprüfung
- KONF.10.5 Überprüfung der Konfiguration
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.2.5 Überprüfung der Konfiguration
- KONF.7.7 Regelmäßiger Funktionstest

- NOT.1.2 Regelmäßige Überprüfung
- NOT.2.1.4 Stabsübung
- NOT.3.4 Funktionstest
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.17 Anwendungstest
- PERS.1.2 Regelmäßige Überprüfung
- PERS.4.1 Qualifikationsbedarf
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- REA.1.2 Regelmäßige Überprüfung
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.3.1 Verbesserung durch Erkenntnisse
- SENS.1.2 Erfolgsmessung
- TEST.1.2 Regelmäßige Überprüfung
- TEST.3.2 Testabdeckung
- TEST.5.5 Rückblick

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- PERF.5.1 Eignungsprüfung
- PERF.7.1 Aktualität der Anforderungen
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- UMS.1.1 Ermittlung des Umsetzungsstatus
- VRB.2.2 Anpassung des ISMS
- VRB.6.1 Wirksamkeitsprüfung

überwachen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.6.10 Monitoring von Zugangsdaten
- DET.4.1 Überwachung der Protokollierung
- DET.4.11 Anomalien in Netzen und am Perimeter

- DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.12.1 Auslastung des Netzes
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.2 Automatische Angriffserkennung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.4.5 Unerwünschte Datenabflüsse
- DET.4.6 Anomale Nutzung der Anwendung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.8.1.1 Unautorisierte Publikation
- DEV.7.2 Zertifikatsmonitoring
- GEB.10.1.2 Klimamessung
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.3.2 Leckagesensor
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.6 Einbruchmeldeanlagen
- GEB.8.4 Überwachung schonender Klimatisierung
- KONF.8.1 Automatische Überprüfung
- PERF.6.1.1 Sicherheitsvorfälle

BSI/Grundschutz/Quellkataloge/Kernel

- BER.6.10 Monitoring von Zugangsdaten
- DET.4.1 Überwachung der Protokollierung
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.11.3 Netzverkehrsfluss

- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.12.1 Auslastung des Netzes
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.2 Automatische Angriffserkennung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.4.5 Unerwünschte Datenabflüsse
- DET.4.6 Anomale Nutzung der Anwendung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.8.1.1 Unautorisierte Publikation
- DEV.7.2 Zertifikatsmonitoring
- GEB.10.1.2 Klimamessung
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.3.2 Leckagesensor
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.6 Einbruchmeldeanlagen
- GEB.8.4 Überwachung schonender Klimatisierung
- KONF.8.1 Automatische Überprüfung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.6.1.1 Sicherheitsvorfälle

untersagen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.15 Keine Gruppenkonten

- BER.7.10 Abgelaufene Schlüssel
- BER.7.9 Zweckbindung
- BES.3.3 Unzuverlässige Lieferanten
- DEV.4.2 Bibliotheksquellen
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.9.7 Zweckentfremdung
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.9.6 Mitnahme ins Ausland

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.15 Keine Gruppenkonten
- BER.7.10 Abgelaufene Schlüssel
- BER.7.9 Zweckbindung
- BES.3.3 Unzuverlässige Lieferanten
- DEV.4.2 Bibliotheksquellen
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.9.7 Zweckentfremdung
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.9.6 Mitnahme ins Ausland

verankern

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1 Verfahren und Regelungen
- ARCH.2.1 Netzsegmente
- ASST.1.1 Verfahren und Regelungen
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.3.14 Reserve physischer Assets
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Lösungsverfahren
- BER.1.1 Verfahren und Regelungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.5 Privilegierte Zugangskonten
- BER.5.8 Entzug von Berechtigungen
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.11 Integrität
- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen

- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BES.1.1 Verfahren und Regelungen
- BES.1.4 Outsourcing-Strategie
- BES.3.2 Auswahlkriterien
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.4.3 Beschaffung anhand der Kriterien
- BES.7.2 Prozesse vor Netzanbindung
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- DET.1.1 Verfahren und Regelungen
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.2.1.3 Rückmeldungen
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.3 Schwachstellenscans
- DET.5.9 Externe Schwachstellenmeldungen
- DET.5.9.1 Bonusprogramm
- DET.6.1 Beurteilung von Ereignissen
- DET.6.2 Beurteilung von Eingängen
- DEV.1.1 Verfahren und Regelungen
- DEV.2.1 Security by Design Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.7.1 Sichere Bereitstellung
- DLS.1.1 Verfahren und Regelungen
- DLS.4.1 Dekommissionierung
- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.11.1 Methodik für das Risikomanagement
- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.7.1 Verfahren und Regelungen

- GC.7.1.4 Prävention von Verstößen
- GC.8.1 Verfahren zur Ressourcenplanung
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
- GC.9.1.2 Kommunikation im Projektmanagement
- GC.9.1.3 Dokumentenlenkung
- GEB.1.1 Verfahren und Regelungen
- GEB.10.2 Brandschutz
- GEB.8.2 Staub und Schmutz
- KONF.1.1 Verfahren und Regelungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.2 Alarmierung
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.12 Georedundanz
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.6.1 Sicherheitsvorfälle
- PERS.1.1 Verfahren und Regelungen
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER

- REA.1.1 Verfahren und Regelungen
- REA.2.4 Diagnosedaten
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.6 Ursachenanalyse und Behandlung
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.3 Koordinierung
- REA.2.6.4 Service Level
- REA.2.6.5 Eskalation
- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.3 Risikoeigentümer
- SENS.1.1 Verfahren und Regelungen
- TEST.1.1 Verfahren und Regelungen
- TEST.3.1.3 Testdaten
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- UMS.3.1 Umsetzungsplanung
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.3.1 Identifikation von Verbesserungspotenzialen
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1 Verfahren und Regelungen
- ARCH.2.1 Netzsegmente
- ASST.1.1 Verfahren und Regelungen
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.3.14 Reserve physischer Assets
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung

- ASST.3.9 Aktualisierung
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.2 Aufbewahrungs- und Löschfristen
 - ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Löschverfahren
- BER.1.1 Verfahren und Regelungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.5 Privilegierte Zugangskonten
- BER.5.8 Entzug von Berechtigungen
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.11 Integrität
- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BES.1.1 Verfahren und Regelungen
- BES.1.4 Outsourcing-Strategie
- BES.3.2 Auswahlkriterien
 - BES.3.2.1 Zertifizierte Lieferanten
 - BES.3.2.2 Quellendiversifikation
- BES.4.3 Beschaffung anhand der Kriterien
- BES.7.2 Prozesse vor Netzanbindung
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- DET.1.1 Verfahren und Regelungen
- DET.2.1 Meldeverfahren
 - DET.2.1.1 Sofortmaßnahmen Nutzender

- DET.2.1.3 Rückmeldungen
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.3 Schwachstellenscans
- DET.5.9 Externe Schwachstellenmeldungen
- DET.5.9.1 Bonusprogramm
- DET.6.1 Beurteilung von Ereignissen
- DET.6.2 Beurteilung von Eingängen
- DEV.1.1 Verfahren und Regelungen
- DEV.2.1 Security by Design Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.7.1 Sichere Bereitstellung
- DLS.1.1 Verfahren und Regelungen
- DLS.4.1 Dekomissionierung
- GEB.1.1 Verfahren und Regelungen
- GEB.10.2 Brandschutz
- GEB.8.2 Staub und Schmutz
- KONF.1.1 Verfahren und Regelungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.2 Alarmierung
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.12 Georedundanz
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung
- PERS.1.1 Verfahren und Regelungen
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung

- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- REA.1.1 Verfahren und Regelungen
- REA.2.4 Diagnosedaten
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.6 Ursachenanalyse und Behandlung
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.3 Koordinierung
- REA.2.6.4 Service Level
- REA.2.6.5 Eskalation
- SENS.1.1 Verfahren und Regelungen
- TEST.1.1 Verfahren und Regelungen
- TEST.3.1.3 Testdaten
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.11.1 Methodik für das Risikomanagement
- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.7.1 Verfahren und Regelungen
- GC.7.1.4 Prävention von Verstößen
- GC.8.1 Verfahren zur Ressourcenplanung
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
- GC.9.1.2 Kommunikation im Projektmanagement
- GC.9.1.3 Dokumentenlenkung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms

- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.6.1 Sicherheitsvorfälle
- UMS.3.1 Umsetzungsplanung
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.3.1 Identifikation von Verbesserungspotenzialen
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.3 Risikoeigentümer
- RISK.1.6 Kritikalitätskriterien für Geschäftsprozesse
- RISK.1.7 Kriterien für die Risikobeurteilung
- RISK.1.8 Kriterien für die Risikoakzeptanz
- RISK.1.9 Bestätigung des Restrisikos

vereinbaren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.4.5 Security by Design
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung
- BES.4.6 Security by Default
- BES.4.6.1 Authentifizierung des Kunden
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.6.3 Manipulationsschutz
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
- BES.4.8.1 Zertifizierung
- BES.4.8.2 Cloud-Konformität

- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.1 Kompetenzen
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.11 Recht auf Audit
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.13.1 Datenbereitstellung
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5 Nutzungsregelungen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Lösungsverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.8.4 Individuelle Implementierung kritischer Komponenten

- BES.8.5 Treuhand
- PERS.3.1 Dienst- oder Arbeitsvertrag
- REA.2.5.3 Forensik-Dienstleister

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.4.5 Security by Design
 - BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
 - BES.4.5.2 Mandantentrennung
- BES.4.6 Security by Default
 - BES.4.6.1 Authentifizierung des Kunden
 - BES.4.6.2 Verschlüsselung durch den Anbieter
 - BES.4.6.3 Manipulationsschutz
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
 - BES.4.8.1 Zertifizierung
 - BES.4.8.2 Cloud-Konformität
 - BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
 - BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.1 Kompetenzen
- BES.5.10 Behandlung von Vorfällen
 - BES.5.10.1 Erreichbarkeit über Meldewege
 - BES.5.10.2 Melden von Vorfällen
 - BES.5.10.3 Schwachstellenbehebung
 - BES.5.10.3.1 Schwachstellenmeldeprozess
 - BES.5.10.4 Konfliktlösungsprozesse
 - BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.11 Recht auf Audit
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
 - BES.5.13.1 Datenbereitstellung
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen

- BES.5.5 Nutzungsregelungen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Löschverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- PERS.3.1 Dienst- oder Arbeitsvertrag
- REA.2.5.3 Forensik-Dienstleister

verschlüsseln

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.3.2 Speicherverschlüsselung
- KONF.4.2.1 DNS-Verschlüsselung
- NOT.4.8 Verschlüsselte Datensicherung

- TEST.5.2 Verschlüsselte Bereitstellung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.3.2 Speicherverschlüsselung
- KONF.4.2.1 DNS-Verschlüsselung
- NOT.4.8 Verschlüsselte Datensicherung
- TEST.5.2 Verschlüsselte Bereitstellung

zuweisen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1.2 Zuweisung der Aufgaben
- ASST.1.1.2 Zuweisung der Aufgaben
- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung
- ASST.3.5 Tainting
- BER.1.1.2 Zuweisung der Aufgaben
- BER.2.1 Person-Identität
- BER.3.4 Identität-Zugangskonto
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.7 IT-System-Zugangskonto
- BER.7.16.1 Zertifizierungsstelle
- BER.7.2 Schlüssellänge
- BES.1.1.2 Zuweisung der Aufgaben
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.8.3 Ressourcensouveränität
- DET.1.1.2 Zuweisung der Aufgaben

- DET.2.2 Security Operations Center
- DEV.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.2 Zuweisung der Aufgaben
- GC.6.1.2 Verpflichtung der Institutionsleitung
- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.2 Stellvertreterregelungen
- GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.7.1 Schlüsselbeauftragte
- KONF.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.2 Zuweisung der Aufgaben
- NOT.2.1.1 Rollen
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.2.4 Zuständigkeiten
- PERS.6.1.2 Neubesetzung
- REA.1.1.2 Zuweisung der Aufgaben
- REA.2.1 Triage und Erstreaktion
- SENS.1.1.2 Zuweisung der Aufgaben
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.2.2.1 Kategorisierung von Änderungen
- UMS.4.1 Benennung von Umsetzungszuständigen
- VRB.5.1 Priorisierung von Maßnahmen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1.2 Zuweisung der Aufgaben
- ASST.1.1.2 Zuweisung der Aufgaben
- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung
- ASST.3.5 Tainting
- BER.1.1.2 Zuweisung der Aufgaben
- BER.2.1 Person-Identität
- BER.3.4 Identität-Zugangskonto
- BER.5.1.1 Rollenbasierte Berechtigung

- BER.5.7 IT-System-Zugangskonto
- BER.7.16.1 Zertifizierungsstelle
- BER.7.2 Schlüssellänge
- BES.1.1.2 Zuweisung der Aufgaben
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.8.3 Ressourcensouveränität
- DET.1.1.2 Zuweisung der Aufgaben
- DET.2.2 Security Operations Center
- DEV.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.7.1 Schlüsselbeauftragte
- KONF.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.2 Zuweisung der Aufgaben
- NOT.2.1.1 Rollen
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.2.4 Zuständigkeiten
- PERS.6.1.2 Neubesetzung
- REA.1.1.2 Zuweisung der Aufgaben
- REA.2.1 Triage und Erstreaktion
- SENS.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.2.2.1 Kategorisierung von Änderungen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1.2 Verpflichtung der Institutionsleitung
- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.2 Stellvertreterregelungen
- GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- UMS.4.1 Benennung von Umsetzungszuständigen
- VRB.5.1 Priorisierung von Maßnahmen

Namespace: documentation_guidelines

Definitionen zu empfohlenen Dokumentationen

https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/raw/refs/heads/main/Dokumentation/namespaces/documentation_guidelines.csv

???

Keine Controls gefunden.

Abnahmeprotokoll

BSI/Grundschrift/Anwenderkatalog/Grundschrift++

- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4 Vollständigkeit der Unterlagen
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung

BSI/Grundschrift/Quellkataloge/Kernel

- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4 Vollständigkeit der Unterlagen
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung

Arbeitsanweisung

BSI/Grundschrift/Anwenderkatalog/Grundschrift++

- ASST.3.1 Nutzungsvereinbarungen

- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.6.3 Konformitätsprüfung
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3 Geregeltes Löschen oder Vernichten
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.6.2.2 Datenträgerschleuse
- DEV.4.2 Bibliotheksquellen
- GC.7.1.4 Prävention von Verstößen
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.3.4 Berechtigungsmarkierung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.9.7 Zweckentfremdung
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- REA.2.6 Ursachenanalyse und Behandlung
- SENS.2.2 Meldewege
- SENS.2.4 Nutzung unautorisierter Assets

- SENS.2.4.1 Verbindung unauthorisierter IT-Systeme
- SENS.2.8 Melden von Ereignissen
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.5.5 Löschfristen
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.14 Unauthorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.4 Begleitung Externer
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.3 Verwahrung außer Haus
- SENS.9.6 Mitnahme ins Ausland

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung

- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.6.3 Konformitätsprüfung
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3 Geregeltes Löschen oder Vernichten
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.6.2.2 Datenträgerschleuse
- DEV.4.2 Bibliotheksquellen
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.3.4 Berechtigungsmarkierung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.9.7 Zweckentfremdung
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- REA.2.6 Ursachenanalyse und Behandlung
- SENS.2.2 Meldewege
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.2.8 Melden von Ereignissen
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.5.5 Löschfristen
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten

- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.4 Begleitung Externer
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.3 Verwahrung außer Haus
- SENS.9.6 Mitnahme ins Ausland

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.7.1.4 Prävention von Verstößen

Arbeitsvertrag

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- PERS.3.1 Dienst- oder Arbeitsvertrag

BSI/Grundschutz/Quellkataloge/Kernel

- PERS.3.1 Dienst- oder Arbeitsvertrag

Audit Log

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.4.4 Nachweis des Zugangs
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.3.3 Protokollierung von Änderungen
- DET.3.1.1 Authentifizierungen
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse

- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.4.11.3 Netzverkehrsfluss
- GEB.3.3.2 Dokumentation von Zutritten
- TEST.2.1 Versionshistorie

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.4.4 Nachweis des Zugangs
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.3.3 Protokollierung von Änderungen
- DET.3.1.1 Authentifizierungen
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.4.11.3 Netzverkehrsfluss
- GEB.3.3.2 Dokumentation von Zutritten
- TEST.2.1 Versionshistorie

Auditbericht

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.4.1.2 Kommunikation an Stakeholder

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.4.1.2 Kommunikation an Stakeholder

Auslagerungsregister

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.7.4.10 Serviceprofil
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DLS.3.1.1 Audit oder Zertifikat

BSI/Grundschutz/Quellkataloge/Kernel

- BES.7.4.10 Serviceprofil
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DLS.3.1.1 Audit oder Zertifikat

BC-Leitlinie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.4 Business Continuity Management System

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.4 Business Continuity Management System

Behandlung von Sicherheitsvorfällen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- REA.2.1 Triage und Erstreaktion
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5 IT-Forensik
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.2.6.4 Service Level
- REA.2.6.5 Eskalation
- REA.3.1 Verbesserung durch Erkenntnisse
- REA.3.1.1 Quantitative Analyse

BSI/Grundschutz/Quellkataloge/Kernel

- REA.2.1 Triage und Erstreaktion
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5 IT-Forensik
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.2.6.4 Service Level
- REA.2.6.5 Eskalation
- REA.3.1 Verbesserung durch Erkenntnisse
- REA.3.1.1 Quantitative Analyse

Bereinigter Netzplan

Keine Controls gefunden.

Betriebshandbuch

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelte Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- DLS.3.4 Anhörung
- DLS.4.1 Dekommissionierung
- DLS.4.1.2 Berechtigungen deaktivieren
- GEB.5.4 Schutz gegen Manipulation
- KONF.3.4 Physischer Diebstahlschutz

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelte Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- DLS.3.4 Anhörung
- DLS.4.1 Dekommissionierung
- DLS.4.1.2 Berechtigungen deaktivieren
- GEB.5.4 Schutz gegen Manipulation
- KONF.3.4 Physischer Diebstahlschutz

Codehistorie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default

Compliance-Verpflichtungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.7.1 Verfahren und Regelungen
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.7.1 Verfahren und Regelungen
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.8.1 Behandlung von Compliance-Verstößen

Datensicherungskonzept

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.4.1 Dokumentation der Quellen
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.11 Datenträgerarchiv
- NOT.4.12 Georedundanz

- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.17 Anwendungstest
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung
- NOT.4.9 Speichermedien

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.4.1 Dokumentation der Quellen
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.11 Datenträgerarchiv
- NOT.4.12 Georedundanz
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.17 Anwendungstest
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung

- NOT.4.9 Speichermedien

Detektionskonzept

Keine Controls gefunden.

Entwicklungsdokumentation

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.2.1 Security by Design Architektur
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.2.1 Security by Design Architektur
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung

Ergebnisprotokoll

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.8 Ereignisgesteuerte Deaktivierung

- DLS.4.1.1 Unabhängigkeit
- TEST.2.2.2 Anpassung der Dokumentation

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.8 Ereignisgesteuerte Deaktivierung
- DLS.4.1.1 Unabhängigkeit
- TEST.2.2.2 Anpassung der Dokumentation

Firewallregeln

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe

- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen

Freigabeplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
 - DEV.2.6.1 Eingabevalidierung
 - DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- TEST.3.1 Sicherheitstest
 - TEST.3.1.1 Dokumentation von Testergebnissen
 - TEST.3.1.10 Penetrationstest bei Änderungen
 - TEST.3.1.2 Integritätstest
 - TEST.3.1.5 Kontinuierliche Tests
 - TEST.3.1.6 Chaos Engineering
 - TEST.3.1.7 Analyse der Zusammensetzung
 - TEST.3.1.8 Fuzzing
 - TEST.3.1.9 Lasttest

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.2.3 Ausführbarkeit mit minimalen Rechten

- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- TEST.3.1 Sicherheitstest
- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.2 Integritätstest
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest

Freigegebene Ausnahmegenehmigung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- UMS.5.2 Dokumentation von Ausnahmen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- UMS.5.2 Dokumentation von Ausnahmen

Gebäudedokumentation

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung

- GEB.10.2 Brandschutz
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.1 Installation von Perimetern
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.5 Einbruchhemmung
- GEB.4.1 Einrichtung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.8.1.1 Archiv
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung

- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.2 Brandschutz
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.1 Installation von Perimetern
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.5 Einbruchhemmung
- GEB.4.1 Einrichtung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.8.1.1 Archiv
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung

Geschäftsprozesse

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.2.1.2 Geschäftsprozessprofile
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- GC.5.1.1 Festlegung der Geschäftsprozesse

BSI/Grundschutz/Quellkataloge/Kernel

- BES.2.1.2 Geschäftsprozessprofile
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.5.1.1 Festlegung der Geschäftsprozesse

Geschäftsverteilungsplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1.2 Zuweisung der Aufgaben
- ASST.1.1.2 Zuweisung der Aufgaben
- BER.1.1.2 Zuweisung der Aufgaben
- BES.1.1.2 Zuweisung der Aufgaben
- DET.1.1.2 Zuweisung der Aufgaben
- DEV.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.2 Zuweisung der Aufgaben
- GC.8.1.2 Stellvertreterregelungen
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.7.1 Schlüsselbeauftragte
- KONF.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.2 Zuweisung der Aufgaben

- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.2.4 Zuständigkeiten
- REA.1.1.2 Zuweisung der Aufgaben
- SENS.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.2 Zuweisung der Aufgaben

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1.2 Zuweisung der Aufgaben
- ASST.1.1.2 Zuweisung der Aufgaben
- BER.1.1.2 Zuweisung der Aufgaben
- BES.1.1.2 Zuweisung der Aufgaben
- DET.1.1.2 Zuweisung der Aufgaben
- DEV.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.7.1 Schlüsselbeauftragte
- KONF.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.2 Zuweisung der Aufgaben
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.2.4 Zuständigkeiten
- REA.1.1.2 Zuweisung der Aufgaben
- SENS.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.2 Zuweisung der Aufgaben

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.8.1.2 Stellvertreterregelungen

Informationssicherheitsleitlinie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.6.1.4 Freigabe der Sicherheitsleitlinie

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.6.1.4 Freigabe der Sicherheitsleitlinie

Informationssicherheitsstrategie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.1 Festlegung einer Sicherheitsstrategie

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.1 Festlegung einer Sicherheitsstrategie

Informationsverbund

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen

Inventar Anwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.2.3 Inventar der Anwendungen
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.2.3.2 Software Bill of Materials (SBOM)

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.2.3 Inventar der Anwendungen
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.2.3.2 Software Bill of Materials (SBOM)

Inventar Berechtigungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.1.1 Verfahren und Regelungen
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.3 Stammdatenprüfung
- BER.2.5 Deaktivierung bei Weggang
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.20 Dienstkonten
- BER.3.21 Notfallzugang
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.3.5 Privilegierte Zugangskonten
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.2 Begründung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur

BSI/Grundschutz/Quellkataloge/Kernel

- BER.1.1 Verfahren und Regelungen
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.3 Stammdatenprüfung
- BER.2.5 Deaktivierung bei Weggang
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.20 Dienstkonten
- BER.3.21 Notfallzugang
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.3.5 Privilegierte Zugangskonten
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.2 Begründung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur

Inventar Berechtigungssysteme

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme

BSI/Grundschutz/Quellkataloge/Kernel

- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme

Inventar Informationen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.2.1 Inventar der Informationen
- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.2.1 Inventar der Informationen
- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung

Inventar IT-Systeme

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.2.2 Inventar der Systeme

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.2.2 Inventar der Systeme

Inventar Standorte

Keine Controls gefunden.

ISMS-Regelwerk

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.10.1 Festlegung von Vorgehensweisen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.10.1 Festlegung von Vorgehensweisen

IT-Betriebskonzept

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1.1 Dokumentation
- ARCH.1.1.3 Bekanntgabe
- ARCH.2.6 Topologieüberwachung
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität

- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.1.1 Verfahren und Regelungen
 - ASST.1.1.1 Dokumentation
 - ASST.1.1.3 Bekanntgabe
- ASST.2.3.2.1 Software Discovery
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.3.15 Ausleihe physischer Assets
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.5 Wartungsfenster
- ASST.5.6 Wartung durch Externe
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen
 - ASST.7.3.1 Standardisierte Vernichtung
 - ASST.7.3.2 Lösungsverfahren
 - ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.2.6 Löschen nach Fristablauf
- BER.3.1 Zentrales Management
 - BER.3.13 Zugang löschen nach Fristablauf
 - BER.3.14 Zugang nur durch zwei Personen
 - BER.3.15 Keine Gruppenkonten
 - BER.3.16 Gruppenkonten - MFA
 - BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.4 Identität-Zugangskonto
- BER.4.1 Identitätsüberprüfung
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.5.8 Entzug von Berechtigungen
- BER.6.1 Passwortmanager
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen

- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.7 Kein Transport privater Schlüssel
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.1.1 Dokumentation
- BES.1.1.3 Bekanntgabe
- DET.1.1.1 Dokumentation
- DET.1.1.3 Bekanntgabe
- DEV.1.1.1 Dokumentation
- DEV.1.1.3 Bekanntgabe
- DLS.1.1.1 Dokumentation
- DLS.1.1.3 Bekanntgabe
- GEB.1.1.1 Dokumentation
- GEB.1.1.3 Bekanntgabe
- GEB.10.1.2 Klimamessung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.8.2 Staub und Schmutz
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- KONF.1.1 Verfahren und Regelungen
- KONF.1.1.1 Dokumentation
- KONF.1.1.3 Bekanntgabe
- KONF.1.3 Management von Werkzeugen

- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- NOT.1.1.1 Dokumentation
- NOT.1.1.3 Bekanntgabe
- PERS.1.1.1 Dokumentation
- PERS.1.1.3 Bekanntgabe
- REA.1.1.1 Dokumentation
- REA.1.1.3 Bekanntgabe
- SENS.1.1.1 Dokumentation
- SENS.1.1.3 Bekanntgabe
- TEST.1.1 Verfahren und Regelungen
- TEST.1.1.1 Dokumentation
- TEST.1.1.3 Bekanntgabe
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.2 Folgenabschätzung
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.3.1.4 Testumgebung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.4.2 Signatur
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- TEST.5.1 Information betroffener Kreise

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1.1 Dokumentation
- ARCH.1.1.3 Bekanntgabe
- ARCH.2.6 Topologieüberwachung
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.1.1 Verfahren und Regelungen

- ASST.1.1.1 Dokumentation
- ASST.1.1.3 Bekanntgabe
- ASST.2.3.2.1 Software Discovery
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.3.15 Ausleihe physischer Assets
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.5 Wartungsfenster
- ASST.5.6 Wartung durch Externe
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Löschverfahren
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.2.6 Löschen nach Fristablauf
- BER.3.1 Zentrales Management
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.15 Keine Gruppenkonten
- BER.3.16 Gruppenkonten - MFA
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.4 Identität-Zugangskonto
- BER.4.1 Identitätsüberprüfung
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.5.8 Entzug von Berechtigungen
- BER.6.1 Passwortmanager
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung

- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.7 Kein Transport privater Schlüssel
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.1.1 Dokumentation
- BES.1.1.3 Bekanntgabe
- DET.1.1.1 Dokumentation
- DET.1.1.3 Bekanntgabe
- DEV.1.1.1 Dokumentation
- DEV.1.1.3 Bekanntgabe
- DLS.1.1.1 Dokumentation
- DLS.1.1.3 Bekanntgabe
- GEB.1.1.1 Dokumentation
- GEB.1.1.3 Bekanntgabe
- GEB.10.1.2 Klimamessung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.8.2 Staub und Schmutz
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- KONF.1.1 Verfahren und Regelungen
- KONF.1.1.1 Dokumentation
- KONF.1.1.3 Bekanntgabe
- KONF.1.3 Management von Werkzeugen
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge

- NOT.1.1.1 Dokumentation
- NOT.1.1.3 Bekanntgabe
- PERS.1.1.1 Dokumentation
- PERS.1.1.3 Bekanntgabe
- REA.1.1.1 Dokumentation
- REA.1.1.3 Bekanntgabe
- SENS.1.1.1 Dokumentation
- SENS.1.1.3 Bekanntgabe
- TEST.1.1 Verfahren und Regelungen
- TEST.1.1.1 Dokumentation
- TEST.1.1.3 Bekanntgabe
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.2 Folgenabschätzung
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.3.1.4 Testumgebung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.4.2 Signatur
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- TEST.5.1 Information betroffener Kreise

Konfigurationshistorie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.2 Dedizierte Hardware
- ARCH.7.3 Entwicklungs- und Testumgebungen

- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.2 Einschränkung des Managements
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.2 Warteraum
- KONF.11.3 Alternative Authentifizierung
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers

- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1 Eingabevalidierung
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.1.9 Journaling
- KONF.12.10 Cookie-Attribute
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- KONF.12.14 DNS-Falschinformationen
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.6 Browser-Historie
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende

- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.4 Caching
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen

- KONF.4.2 DNS-Anbindung
 - KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.5.1 Authentifizierung am System
 - KONF.5.1.1 Authentifizierung an der Firmware
 - KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
 - KONF.6.1.1 Datenkapselung
 - KONF.6.1.2 Isolierung von Anwendungen
 - KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.3 Kiosk-Modus
- KONF.6.4 Privilegierte Systemfunktionen
 - KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.6 Getrennte Datenhaltung
 - KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit

- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.8.2 Automatische Updates der Anwendung
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- REA.2.2 Automatische Erstreaktion
- TEST.3.1.3 Testdaten
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.3 Schrittweiser Rollout
- TEST.5.4 Persistenz

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.2 Dedizierte Hardware
- ARCH.7.3 Entwicklungs- und Testumgebungen
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung

- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.2 Einschränkung des Managements
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.2 Warteraum
- KONF.11.3 Alternative Authentifizierung
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1 Eingabevalidierung
- KONF.12.1.1 Zertifikatsprüfung

- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.1.9 Journaling
- KONF.12.10 Cookie-Attribute
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- KONF.12.14 DNS-Falschinformationen
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.6 Browser-Historie
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports

- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.1 Verschlüsselung beim Transport
 - KONF.14.1.1 Obligatorische Verschlüsselung
 - KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.4 Caching
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.1 Grundkonfiguration für Systeme
 - KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
 - KONF.2.4.1 Nicht benötigte Zertifikate
 - KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
 - KONF.2.5.1 Automatische Konfigurationsverwaltung
 - KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
 - KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
 - KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2 DNS-Anbindung
 - KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen

- KONF.5.1 Authentifizierung am System
 - KONF.5.1.1 Authentifizierung an der Firmware
 - KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
 - KONF.6.1.1 Datenkapselung
 - KONF.6.1.2 Isolierung von Anwendungen
 - KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.3 Kiosk-Modus
- KONF.6.4 Privilegierte Systemfunktionen
 - KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.6 Getrennte Datenhaltung
 - KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitsscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit
 - KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzwerkverkehr
- KONF.7.5 Alarmierung

- KONF.7.6 Automatische Updates
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.8.2 Automatische Updates der Anwendung
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- REA.2.2 Automatische Erstreaktion
- TEST.3.1.3 Testdaten
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.3 Schrittweiser Rollout
- TEST.5.4 Persistenz

Leistungsbeschreibung

Keine Controls gefunden.

Leitlinie zur Informationssicherheit

Keine Controls gefunden.

Leitungsentscheidung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.6.1.2 Verpflichtung der Institutionsleitung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1.2 Verpflichtung der Institutionsleitung

Liste der Hersteller und Dienstleister

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- REA.2.5.3 Forensik-Dienstleister

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- REA.2.5.3 Forensik-Dienstleister

Liste der Verpflichtungen

Keine Controls gefunden.

Managementbericht

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.10.2 Freigabe von Vorgehensweisen
- PERF.5.1 Eignungsprüfung
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERF.5.1.9 Maßnahmenvorschläge

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.10.2 Freigabe von Vorgehensweisen
- PERF.5.1 Eignungsprüfung
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen

- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERF.5.1.9 Maßnahmenvorschläge

Netzplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.12 Sprungserver
 - ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.3 Mikrosegmentierung
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.3.1 Netzabdeckung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.3.3 SSIDs

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse

- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.3 Mikrosegmentierung
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.3.1 Netzabdeckung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.3.3 SSIDs

Notfallhandbuch

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.2.1 Verfahren und Regelungen
 - NOT.2.1.1 Rollen
 - NOT.2.1.2 Alarmierung
 - NOT.2.1.3 Stabsraum
 - NOT.2.1.4 Stabsübung
- NOT.3.1 Wiederanlaufplan
- NOT.3.2 Geschäftsfortführungsplan
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.2.1 Verfahren und Regelungen
 - NOT.2.1.1 Rollen
 - NOT.2.1.2 Alarmierung
 - NOT.2.1.3 Stabsraum

- NOT.2.1.4 Stabsübung
- NOT.3.1 Wiederanlaufplan
- NOT.3.2 Geschäftsfortführungsplan
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen

Nutzungsbedingungen

Keine Controls gefunden.

Outsourcing-Strategie

Keine Controls gefunden.

Prozess Beschaffung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.1 Verfahren und Regelungen
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.3 Beschaffung anhand der Kriterien
- BES.8.1 Bereithaltung alternativer Lieferanten
- DLS.1.1 Verfahren und Regelungen
- DLS.3.5 Blockierung unzuverlässiger Dienstleister

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.1 Verfahren und Regelungen
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.3 Beschaffung anhand der Kriterien
- BES.8.1 Bereithaltung alternativer Lieferanten
- DLS.1.1 Verfahren und Regelungen

- DLS.3.5 Blockierung unzuverlässiger Dienstleister

Prozess Dienstleistersteuerung

Keine Controls gefunden.

Prozess Gebäudemanagement

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.1.1 Verfahren und Regelungen
- GEB.1.3 Autorisierung von Standorten
- GEB.1.3.1 Abnahme von Standorten
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.3 Besucheranmeldung
- GEB.3.6 Einbruchmeldeanlagen

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.1.1 Verfahren und Regelungen
- GEB.1.3 Autorisierung von Standorten
- GEB.1.3.1 Abnahme von Standorten
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.3 Besucheranmeldung
- GEB.3.6 Einbruchmeldeanlagen

Prozess Identitäts- und Berechtigungsmanagement

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.1.1.1 Dokumentation

- BER.1.1.3 Bekanntgabe
- BER.2.2 Einschränkung
- GEB.4.2 Gesonderte Autorisierung

BSI/Grundschutz/Quellkataloge/Kernel

- BER.1.1.1 Dokumentation
- BER.1.1.3 Bekanntgabe
- BER.2.2 Einschränkung
- GEB.4.2 Gesonderte Autorisierung

Prozess Personalmanagement

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- PERS.1.1 Verfahren und Regelungen
- PERS.3.4 Stellenbeschreibungen
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.3.7 Einarbeitung
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung

BSI/Grundschutz/Quellkataloge/Kernel

- PERS.1.1 Verfahren und Regelungen
- PERS.3.4 Stellenbeschreibungen
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.3.7 Einarbeitung
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen

- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung

Prüfplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.1.2 Regelmäßige Überprüfung
- BER.5.3 Überprüfung von Berechtigungen

BSI/Grundschutz/Quellkataloge/Kernel

- BER.1.2 Regelmäßige Überprüfung
- BER.5.3 Überprüfung von Berechtigungen

Realisierungsplan

Keine Controls gefunden.

Richtlinie zur Lenkung von Dokumenten und Aufzeichnungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.9.1.3 Dokumentenlenkung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.9.1.3 Dokumentenlenkung

Richtlinie zur Risikoanalyse

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.3 Risikoeigentümer
- RISK.1.5 Freigabe des Risikomanagements

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.2 Einhaltung der BSI-Kriterien
- RISK.1.3 Risikoeigentümer
- RISK.1.4 Risikoappetit
- RISK.1.5 Freigabe des Risikomanagements
- RISK.1.6 Kritikalitätskriterien für Geschäftsprozesse
- RISK.1.7 Kriterien für die Risikobeurteilung
- RISK.1.8 Kriterien für die Risikoakzeptanz

Risikobewertung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.11.1 Methodik für das Risikomanagement
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.11.1 Methodik für das Risikomanagement
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf

Schulungsplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling

- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.6 Papiervernichtung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links

- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.5 Verwahrung Intern
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe

- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.6 Papiervernichtung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.5 Verwahrung Intern
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise

Schutzbedarfsfeststellung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.5.1.2 Festlegung des Schutzbedarfs

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.5.1.2 Festlegung des Schutzbedarfs

Sicherheitsorganisation

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.4 Festlegung einer Sicherheitsorganisation

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.4 Festlegung einer Sicherheitsorganisation

Tätigkeits- & Rollenbeschreibung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.8.1.5 Sicherstellung der Qualifikation

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.8.1.5 Sicherstellung der Qualifikation

Übersicht der Kommunikationspartner

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement

Übungsplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.3.4 Funktionstest
- REA.1.3 Übungen zur Vorfallsbehandlung
- SENS.1.2 Erfolgsmessung

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.3.4 Funktionstest
- REA.1.3 Übungen zur Vorfallsbehandlung
- SENS.1.2 Erfolgsmessung

Umsetzungsplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- RISK.1.10 Freigabe der Umsetzungsplanung
- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- VRB.5.1 Priorisierung von Maßnahmen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- VRB.5.1 Priorisierung von Maßnahmen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.9 Bestätigung des Restrisikos

Verfahrensbeschreibung

Keine Controls gefunden.

Verträge

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.4.5 Vereinbarungen zum Austausch

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.4.5 Vereinbarungen zum Austausch

Verzeichnis der Schwachstellen

Keine Controls gefunden.

Verzeichnis öffentlicher Schlüssel

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.2 Schlüssellänge
- BER.7.3 Verzeichnis öffentlicher Schlüssel

BSI/Grundschutz/Quellkataloge/Kernel

- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16.5 Beglaubigungsstatus

- BER.7.16.6 Revocationstatus
- BER.7.2 Schlüssellänge
- BER.7.3 Verzeichnis öffentlicher Schlüssel

Namespace: effort_level

Effort level: 0

Der Aufwand der Anforderung wird nicht bewertet, da ihre Implementierung in jedem Fall zwingend erforderlich ist. Beispiel: Benennung eines Informationssicherheitsbeauftragten.

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1 Verfahren und Regelungen
 - ARCH.1.1.1 Dokumentation
 - ARCH.1.1.2 Zuweisung der Aufgaben
 - ARCH.1.1.3 Bekanntgabe
- ARCH.1.2 Regelmäßige Überprüfung
- ASST.1.1 Verfahren und Regelungen
 - ASST.1.1.1 Dokumentation
 - ASST.1.1.2 Zuweisung der Aufgaben
 - ASST.1.1.3 Bekanntgabe
- ASST.1.2 Regelmäßige Überprüfung
- BER.1.1 Verfahren und Regelungen
 - BER.1.1.1 Dokumentation
 - BER.1.1.2 Zuweisung der Aufgaben
 - BER.1.1.3 Bekanntgabe
- BER.1.2 Regelmäßige Überprüfung
- BES.1.1 Verfahren und Regelungen
 - BES.1.1.1 Dokumentation
 - BES.1.1.2 Zuweisung der Aufgaben
 - BES.1.1.3 Bekanntgabe
- BES.1.2 Regelmäßige Überprüfung
- DET.1.1 Verfahren und Regelungen
 - DET.1.1.1 Dokumentation
 - DET.1.1.2 Zuweisung der Aufgaben
 - DET.1.1.3 Bekanntgabe
- DET.1.2 Regelmäßige Überprüfung
- DEV.1.1 Verfahren und Regelungen
 - DEV.1.1.1 Dokumentation
 - DEV.1.1.2 Zuweisung der Aufgaben
 - DEV.1.1.3 Bekanntgabe

- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.1 Verfahren und Regelungen
 - DLS.1.1.1 Dokumentation
 - DLS.1.1.2 Zuweisung der Aufgaben
 - DLS.1.1.3 Bekanntgabe
- DLS.1.2 Regelmäßige Überprüfung
- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.10.1 Festlegung von Vorgehensweisen
- GC.10.2 Freigabe von Vorgehensweisen
- GC.11.1 Methodik für das Risikomanagement
- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
 - GC.5.1.1 Festlegung der Geschäftsprozesse
 - GC.5.1.2 Festlegung des Schutzbedarfs
 - GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
 - GC.6.1.2 Verpflichtung der Institutionsleitung
 - GC.6.1.3 Erstellung einer Sicherheitsleitlinie
 - GC.6.1.4 Freigabe der Sicherheitsleitlinie
- GC.7.1 Verfahren und Regelungen
- GC.8.1 Verfahren zur Ressourcenplanung
 - GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
 - GC.8.1.1.1 Informationssicherheitsbeauftragter
 - GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
 - GC.8.1.2 Stellvertreterregelungen
 - GC.8.1.3 Vermeidung von Interessenkonflikten
 - GC.8.1.4 Festlegung einer Sicherheitsorganisation
 - GC.8.1.5 Sicherstellung der Qualifikation
 - GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
 - GC.9.1.2 Kommunikation im Projektmanagement
 - GC.9.1.3 Dokumentenlenkung
- GEB.1.1 Verfahren und Regelungen
 - GEB.1.1.1 Dokumentation

- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.3 Bekanntgabe
- GEB.1.2 Regelmäßige Überprüfung
- KONF.1.1 Verfahren und Regelungen
- KONF.1.1.1 Dokumentation
- KONF.1.1.2 Zuweisung der Aufgaben
- KONF.1.1.3 Bekanntgabe
- KONF.1.2 Regelmäßige Überprüfung
- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.1 Dokumentation
- NOT.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.3 Bekanntgabe
- NOT.1.2 Regelmäßige Überprüfung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
- PERF.3.1.2 Planen von internen Audits
- PERF.3.1.3 Auswahl des Auditteams
- PERF.3.1.4 Umfang von Audits
- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.4.1.2 Kommunikation an Stakeholder
- PERF.5.1 Eignungsprüfung
- PERF.5.1.9 Maßnahmenvorschläge
- PERF.5.2 Bericht an die Institutionsleitung
- PERF.6.1 Sicherheitsvorfälle
- PERF.6.1.1 Sicherheitsvorfälle
- PERF.6.1.2 Schwachstellen
- PERF.6.1.3 Bedrohungen
- PERF.7.1 Aktualität der Anforderungen
- PERS.1.1 Verfahren und Regelungen
- PERS.1.1.1 Dokumentation
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.1.1.3 Bekanntgabe
- PERS.1.2 Regelmäßige Überprüfung
- REA.1.1 Verfahren und Regelungen
- REA.1.1.1 Dokumentation
- REA.1.1.2 Zuweisung der Aufgaben
- REA.1.1.3 Bekanntgabe
- REA.1.2 Regelmäßige Überprüfung

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.3 Risikoeigentümer
- RISK.1.5 Freigabe des Risikomanagements
- SENS.1.1 Verfahren und Regelungen
- SENS.1.1.1 Dokumentation
- SENS.1.1.2 Zuweisung der Aufgaben
- SENS.1.1.3 Bekanntgabe
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes
- STM.4.1 Erfassung relevanter Assets
- STM.4.2 Dokumentation relevanter Assets
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- TEST.1.1 Verfahren und Regelungen
- TEST.1.1.1 Dokumentation
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.3 Bekanntgabe
- TEST.1.2 Regelmäßige Überprüfung
- UMS.1.1 Ermittlung des Umsetzungsstatus
- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.5.1 Autorisierung von Ausnahmen
- UMS.5.2 Dokumentation von Ausnahmen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts

- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen
- VRB.5.1 Priorisierung von Maßnahmen
- VRB.6.1 Wirksamkeitsprüfung

BSI/Grundschrift/Quellkataloge/Kernel

- ARCH.1.1 Verfahren und Regelungen
 - ARCH.1.1.1 Dokumentation
 - ARCH.1.1.2 Zuweisung der Aufgaben
 - ARCH.1.1.3 Bekanntgabe
- ARCH.1.2 Regelmäßige Überprüfung
- ASST.1.1 Verfahren und Regelungen
 - ASST.1.1.1 Dokumentation
 - ASST.1.1.2 Zuweisung der Aufgaben
 - ASST.1.1.3 Bekanntgabe
- ASST.1.2 Regelmäßige Überprüfung
- BER.1.1 Verfahren und Regelungen
 - BER.1.1.1 Dokumentation
 - BER.1.1.2 Zuweisung der Aufgaben
 - BER.1.1.3 Bekanntgabe
- BER.1.2 Regelmäßige Überprüfung
- BES.1.1 Verfahren und Regelungen
 - BES.1.1.1 Dokumentation
 - BES.1.1.2 Zuweisung der Aufgaben
 - BES.1.1.3 Bekanntgabe
- BES.1.2 Regelmäßige Überprüfung
- DET.1.1 Verfahren und Regelungen
 - DET.1.1.1 Dokumentation
 - DET.1.1.2 Zuweisung der Aufgaben
 - DET.1.1.3 Bekanntgabe
- DET.1.2 Regelmäßige Überprüfung
- DEV.1.1 Verfahren und Regelungen

- DEV.1.1.1 Dokumentation
- DEV.1.1.2 Zuweisung der Aufgaben
- DEV.1.1.3 Bekanntgabe
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.1 Verfahren und Regelungen
- DLS.1.1.1 Dokumentation
- DLS.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.3 Bekanntgabe
- DLS.1.2 Regelmäßige Überprüfung
- GEB.1.1 Verfahren und Regelungen
- GEB.1.1.1 Dokumentation
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.3 Bekanntgabe
- GEB.1.2 Regelmäßige Überprüfung
- KONF.1.1 Verfahren und Regelungen
- KONF.1.1.1 Dokumentation
- KONF.1.1.2 Zuweisung der Aufgaben
- KONF.1.1.3 Bekanntgabe
- KONF.1.2 Regelmäßige Überprüfung
- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.1 Dokumentation
- NOT.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.3 Bekanntgabe
- NOT.1.2 Regelmäßige Überprüfung
- PERS.1.1 Verfahren und Regelungen
- PERS.1.1.1 Dokumentation
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.1.1.3 Bekanntgabe
- PERS.1.2 Regelmäßige Überprüfung
- REA.1.1 Verfahren und Regelungen
- REA.1.1.1 Dokumentation
- REA.1.1.2 Zuweisung der Aufgaben
- REA.1.1.3 Bekanntgabe
- REA.1.2 Regelmäßige Überprüfung
- SENS.1.1 Verfahren und Regelungen
- SENS.1.1.1 Dokumentation
- SENS.1.1.2 Zuweisung der Aufgaben
- SENS.1.1.3 Bekanntgabe

- TEST.1.1 Verfahren und Regelungen
- TEST.1.1.1 Dokumentation
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.3 Bekanntgabe
- TEST.1.2 Regelmäßige Überprüfung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.10.1 Festlegung von Vorgehensweisen
- GC.10.2 Freigabe von Vorgehensweisen
- GC.11.1 Methodik für das Risikomanagement
- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.2 Verpflichtung der Institutionsleitung
- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.6.1.4 Freigabe der Sicherheitsleitlinie
- GC.7.1 Verfahren und Regelungen
- GC.8.1 Verfahren zur Ressourcenplanung
- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.8.1.2 Stellvertreterregelungen
- GC.8.1.3 Vermeidung von Interessenkonflikten
- GC.8.1.4 Festlegung einer Sicherheitsorganisation
- GC.8.1.5 Sicherstellung der Qualifikation
- GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
- GC.9.1.2 Kommunikation im Projektmanagement
- GC.9.1.3 Dokumentenlenkung

- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
- PERF.3.1.2 Planen von internen Audits
- PERF.3.1.3 Auswahl des Auditteams
- PERF.3.1.4 Umfang von Audits
- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.4.1.2 Kommunikation an Stakeholder
- PERF.5.1 Eignungsprüfung
- PERF.5.1.9 Maßnahmenvorschläge
- PERF.5.2 Bericht an die Institutionsleitung
- PERF.6.1 Sicherheitsvorfälle
- PERF.6.1.1 Sicherheitsvorfälle
- PERF.6.1.2 Schwachstellen
- PERF.6.1.3 Bedrohungen
- PERF.7.1 Aktualität der Anforderungen
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes
- STM.4.1 Erfassung relevanter Assets
- STM.4.2 Dokumentation relevanter Assets
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- UMS.1.1 Ermittlung des Umsetzungsstatus
- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.5.1 Autorisierung von Ausnahmen

- UMS.5.2 Dokumentation von Ausnahmen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen
- VRB.5.1 Priorisierung von Maßnahmen
- VRB.6.1 Wirksamkeitsprüfung

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.2 Einhaltung der BSI-Kriterien
- RISK.1.3 Risikoeigentümer
- RISK.1.4 Risikoappetit
- RISK.1.5 Freigabe des Risikomanagements
- RISK.1.6 Kritikalitätskriterien für Geschäftsprozesse
- RISK.1.7 Kriterien für die Risikobeurteilung
- RISK.1.8 Kriterien für die Risikoakzeptanz

Effort level: 1

In der Regel ist die Umsetzung noch am selben Tag und mit wenig Aufwand erreichbar. Zur Aufrechterhaltung sind keine regelmäßigen Aufwände erforderlich (Sogenannte Quick Wins / low hanging fruit). Beispiel: Aktivierung einer typischerweise vorhandenen Systemfunktion.

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.21 Notfallzugang
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.13 Gültigkeit
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.3.4 Passwort-Hashing
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.9 Journaling
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.5.1 Authentifizierung am System

- KONF.5.1.1 Authentifizierung an der Firmware
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.2.1 Schutzziele
- SENS.2.7 Änderung von Konfigurationen
- SENS.4.1.5 Biometrische Authentifikation
- SENS.7.15 Social Engineering Anrufe
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.21 Notfallzugang
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.13 Gültigkeit
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.3.4 Passwort-Hashing
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- KONF.10.3 Änderung von Default-Zugangsdaten

- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.9 Journaling
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.2.1 Schutzziele
- SENS.2.7 Änderung von Konfigurationen
- SENS.4.1.5 Biometrische Authentifikation
- SENS.7.15 Social Engineering Anrufe
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern

- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen

Effort level: 2

In der Regel ist die Umsetzung innerhalb einer Woche mit eigenen Mitteln möglich. Zur Aufrechterhaltung sind nur geringe Aufwände erforderlich. Beispiel: Erstellung einer Kontaktübersicht, die mit mehreren Fachbereichen abgestimmt werden muss.

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
- ARCH.2.2.1 Externe Netzanschlüsse
- ARCH.2.2.2 Gastnetz
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.3.1 Netzabdeckung
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ASST.2.2 Inventar der Systeme
- ASST.2.3 Inventar der Anwendungen
- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.3 Geregeltes Löschen oder Vernichten
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.15 Keine Gruppenkonten
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.2 Einschränkung des Managements
- BER.3.4 Identität-Zugangskonto
- BER.3.5 Privilegierte Zugangskonten
- BER.3.9 Anmeldeversuchsgrenze am System

- BER.6.1 Passwortmanager
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- BER.6.7 Trivialpasswörter
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.12 Authentizität
- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.2 Schlüssellänge
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.2.1 Erfassung des Bedarfes
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.5 Security by Design
- BES.4.6 Security by Default
- BES.4.6.1 Authentifizierung des Kunden
- BES.5.8 Rechte für geistiges Eigentum
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.6 Rückgewähr von Assets
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.7 Organisatorische Schnittstellen
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.8 Privilegierte Ereignisse
- DEV.2.1 Security by Design Architektur
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6.2 Ausgabekodierung
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.2 Bibliotheksquellen
- DEV.4.5 Updates externer Softwarebibliotheken

- DEV.4.8 Default-Zugangsdaten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.7.2 Zertifikatsmonitoring
- DLS.2.2 Transportverschlüsselung
- DLS.4.1 Dekommissionierung
- GEB.1.3 Autorisierung von Standorten
- GEB.10.2 Brandschutz
- GEB.10.3 Wasserschutz
- GEB.2.1 Installation von Perimetern
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.8.1 Gesonderte Aufbewahrung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.14.1 Verschlüsselung beim Transport
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.3.3 SIM-PIN
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.14 Browser Sandboxing
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.15 Lokale Firewall
- KONF.7.2 Regelmäßige Scans
- KONF.7.6 Automatische Updates
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.2 Automatische Updates der Anwendung
- NOT.4.1 Dokumentation der Quellen
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.6 Geschützte Aufbewahrung

- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.4 Zuständigkeiten
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung
- REA.2.1 Triage und Erstreaktion
- REA.2.6 Ursachenanalyse und Behandlung
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.2.2 Meldewege
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung

- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.9 Aktive Inhalte
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.5 Verwahrung Intern
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.2 Folgenabschätzung
- TEST.2.2.2 Anpassung der Dokumentation
- UMS.2.1 Bewertung des Restrisikos
- VRB.2.2 Anpassung des ISMS
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
- ARCH.2.2.1 Externe Netzanschlüsse
- ARCH.2.2.2 Gastnetz
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.3.1 Netzabdeckung
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung

- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ASST.2.2 Inventar der Systeme
- ASST.2.3 Inventar der Anwendungen
- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.3 Geregeltes Löschen oder Vernichten
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.15 Keine Gruppenkonten
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.2 Einschränkung des Managements
- BER.3.4 Identität-Zugangskonto
- BER.3.5 Privilegierte Zugangskonten
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.1 Passwortmanager
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- BER.6.7 Trivialpasswörter
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.12 Authentizität
- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.2 Schlüssellänge
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.2.1 Erfassung des Bedarfs
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben

- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.5 Security by Design
- BES.4.6 Security by Default
- BES.4.6.1 Authentifizierung des Kunden
- BES.5.8 Rechte für geistiges Eigentum
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.6 Rückgewähr von Assets
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.7 Organisatorische Schnittstellen
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.8 Privilegierte Ereignisse
- DEV.2.1 Security by Design Architektur
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6.2 Ausgabekodierung
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.2 Bibliotheksquellen
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.8 Default-Zugangsdaten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.7.2 Zertifikatsmonitoring
- DLS.2.2 Transportverschlüsselung
- DLS.4.1 Dekommissionierung
- GEB.1.3 Autorisierung von Standorten
- GEB.10.2 Brandschutz
- GEB.10.3 Wasserschutz
- GEB.2.1 Installation von Perimetern
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.8.1 Gesonderte Aufbewahrung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.4 Speicherung von Zugangsdaten

- KONF.14.1 Verschlüsselung beim Transport
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.3.3 SIM-PIN
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.14 Browser Sandboxing
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.15 Lokale Firewall
- KONF.7.2 Regelmäßige Scans
- KONF.7.6 Automatische Updates
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.2 Automatische Updates der Anwendung
- NOT.4.1 Dokumentation der Quellen
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.6 Geschützte Aufbewahrung
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.4 Zuständigkeiten
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung
- REA.2.1 Triage und Erstreaktion
- REA.2.6 Ursachenanalyse und Behandlung

- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.2.2 Meldewege
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.9 Aktive Inhalte
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.5 Verwahrung Intern
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.2 Folgenabschätzung
- TEST.2.2.2 Anpassung der Dokumentation

BSI/Grundschrift/Quellkataloge/Methodik-Grundschrift++

- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- UMS.2.1 Bewertung des Restrisikos
- VRB.2.2 Anpassung des ISMS
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschrift/Quellkataloge/Risikomanagement

- RISK.1.9 Bestätigung des Restrisikos

Effort level: 3

In der Regel ist für die Umsetzung ein Zeitraum über mehrere Wochen bis einige Monate erforderlich. Je nach Ressourcen der Institution kann hierzu auch eine Beteiligung externer Dienstleister erforderlich sein. Die Aufrechterhaltung kann von einem kleinen Team an Betriebspersonal gewährleistet werden. Beispiel: Unterbringung von Geräten im Serverraum.

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.9 Filterung von DNS
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.2.1 Inventar der Informationen
- ASST.2.1.1 Informationsverantwortung
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.2.4 Klassifizierung
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.5.1 Wartungsbedarf dokumentieren

- ASST.5.2 Geregelte Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Löschverfahren
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.2 Einschränkung
- BER.2.3 Stammdatenprüfung
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.2.5 Deaktivierung bei Weggang
- BER.3.1 Zentrales Management
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.3 Protokollierung von Änderungen
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.4.1 Identitätsüberprüfung
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.2 Begründung von Berechtigungen
- BER.5.3 Überprüfung von Berechtigungen
- BER.5.8 Entzug von Berechtigungen
- BER.6.10 Monitoring von Zugangsdaten
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BER.7.5 Kriterien für die Qualität von Zufallszahlen

- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.1.1 Verwendungszweck
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.4 Kompatibilität
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.14 Löschregeln
- BES.5.3 Compliance-Verpflichtungen
- BES.5.5 Nutzungsregelungen
- BES.6.2 Löschung von Daten
- BES.6.3 Übertragbarkeit von Daten
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.10 Serviceprofil
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.6 Shared Responsibility
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler

- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.9 Fehler der Anwendung
- DET.3.5 Unbestreitbarkeit
- DET.4.11.2 Netzwerk-Honeypots
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.4.6 Anomale Nutzung der Anwendung
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.2 Schwachstellenregister
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.3.3 Historische Analyse
- DET.5.8.1.1 Unautorisierte Publikation
- DET.6.1 Beurteilung von Ereignissen
- DET.6.1.2 Automatische Alarmierung
- DET.6.2.2 Datenträgerschleuse
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.6.1 Eingabevalidierung
- DEV.3.1 Replay-Angriffe
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.6 Compileroptionen
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren
- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- GC.7.1.4 Prävention von Verstößen

- GEB.1.3.1 Abnahme von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.1.2 Klimamessung
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.3 Besucheranmeldung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.3 Schlüsselaudit
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung
- KONF.1.3 Management von Werkzeugen
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.11.2 Warteraum
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1 Eingabevalidierung

- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.10 Cookie-Attribute
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- KONF.12.14 DNS-Falschinformationen
- KONF.12.3 Cookies
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.2 DNS-Anbindung
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.5 Alarmierung
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.13 Datensouveränität

- NOT.4.14 Offline-Kopie
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung
- NOT.4.9 Speichermedien
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERS.2.3 Rollentrennung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.3.4 Stellenbeschreibungen
- PERS.5.1 Maßregelung
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5 IT-Forensik
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.3.1 Verbesserung durch Erkenntnisse
- SENS.1.2 Erfolgsmessung
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.5.1 Datenablage
- SENS.7.12 Öffentliche WLANs

- SENS.7.2 Virenskan
- SENS.7.25 Zugang zum Fahrzeug
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.3 Verwahrung außer Haus
- SENS.9.6 Mitnahme ins Ausland
- TEST.2.1 Versionshistorie
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.3.1 Sicherheitstest
- TEST.3.1.2 Integritätstest
- TEST.3.2 Testabdeckung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelter Notfalländerungen
- TEST.5.1 Information betroffener Kreise
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.4 Persistenz
- VRB.3.1 Identifikation von Verbesserungspotenzialen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.9 Filterung von DNS
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.9.1 Dimensionierung der Netzanbindung

- ASST.2.1 Inventar der Informationen
- ASST.2.1.1 Informationsverantwortung
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.2.4 Klassifizierung
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelte Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Löschverfahren
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.2 Einschränkung
- BER.2.3 Stammdatenprüfung
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.2.5 Deaktivierung bei Weggang
- BER.3.1 Zentrales Management
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.3 Protokollierung von Änderungen
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.4.1 Identitätsüberprüfung
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.2 Begründung von Berechtigungen

- BER.5.3 Überprüfung von Berechtigungen
- BER.5.8 Entzug von Berechtigungen
- BER.6.10 Monitoring von Zugangsdaten
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.1.1 Verwendungszweck
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.4 Kompatibilität
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.14 Löschregeln
- BES.5.3 Compliance-Verpflichtungen
- BES.5.5 Nutzungsregelungen
- BES.6.2 Löschung von Daten
- BES.6.3 Übertragbarkeit von Daten
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck

- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.10 Serviceprofil
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.6 Shared Responsibility
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.9 Fehler der Anwendung
- DET.3.5 Unbestreitbarkeit
- DET.4.11.2 Netzwerk-Honeypots
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.4.6 Anomale Nutzung der Anwendung
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.2 Schwachstellenregister
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.3.3 Historische Analyse
- DET.5.8.1.1 Unautorisierte Publikation
- DET.6.1 Beurteilung von Ereignissen
- DET.6.1.2 Automatische Alarmierung
- DET.6.2.2 Datenträgerschleuse
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.6.1 Eingabevalidierung
- DEV.3.1 Replay-Angriffe
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.4.3 Softwarebestandteile (SBOM)

- DEV.4.6 Compileroptionen
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren
- GEB.1.3.1 Abnahme von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.1.2 Klimamessung
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.3 Besucheranmeldung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.3 Schlüsselaudit
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung
- KONF.1.3 Management von Werkzeugen
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen

- KONF.11.2 Warteraum
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
 - KONF.11.8.1 Einschränkung von Zonentransfers
 - KONF.11.8.2 Einschränkung von TK-Verbindungen
 - KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1 Eingabevalidierung
 - KONF.12.1.10 HTTP-Response-Header
 - KONF.12.1.7 Filtern schädlicher Webinhalte
 - KONF.12.1.8 Duplikate im Verzeichnisbaum
 - KONF.12.10 Cookie-Attribute
 - KONF.12.12 Verbindungsprotokoll
 - KONF.12.13 Sendebericht
 - KONF.12.14 DNS-Falschinformationen
- KONF.12.3 Cookies
- KONF.13.1 Filtern schädlicher Nachrichten
 - KONF.13.1.1 SPAM-Filter
 - KONF.13.2.1 Verifikation der Sendeberechtigung
 - KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.2.1 Grundkonfiguration für Systeme
 - KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
 - KONF.2.4.1 Nicht benötigte Zertifikate
 - KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.2 DNS-Anbindung
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation

- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.5 Alarmierung
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung
- NOT.4.9 Speichermedien
- PERS.2.3 Rollentrennung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.3.4 Stellenbeschreibungen
- PERS.5.1 Maßregelung
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5 IT-Forensik
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.3.1 Verbesserung durch Erkenntnisse
- SENS.1.2 Erfolgsmessung
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe

- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.5.1 Datenablage
- SENS.7.12 Öffentliche WLANs
- SENS.7.2 Virenskan
- SENS.7.25 Zugang zum Fahrzeug
- SENS.8.7 Verwendung von Brandschutzmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.3 Verwahrung außer Haus
- SENS.9.6 Mitnahme ins Ausland
- TEST.2.1 Versionshistorie
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.3.1 Sicherheitstest
- TEST.3.1.2 Integritätstest
- TEST.3.2 Testabdeckung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- TEST.5.1 Information betroffener Kreise
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.4 Persistenz

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- GC.7.1.4 Prävention von Verstößen
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- VRB.3.1 Identifikation von Verbesserungspotenzialen

Effort level: 4

In der Regel sind diese Anforderungen mit einer längerfristigen Umsetzung oder Beibehaltung verbunden. Es wird Expertenwissen und oftmals auch eine Unterstützung von Dritten benötigt. Für die Aufrechterhaltung ist häufig ein größeres Team von Betriebspersonal erforderlich. Beispiel: Initiierung und Umsetzung von Baumaßnahmen.

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.6 Topologieüberwachung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ARCH.7.3 Entwicklungs- und Testumgebungen
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.14 Reserve physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.6 Wartung durch Externe
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- BER.2.6 Löschen nach Fristablauf

- BER.3.16 Gruppenkonten - MFA
- BER.3.20 Dienstkonten
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BES.1.4 Outsourcing-Strategie
- BES.1.4.1 Freigabe der Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
- BES.4.8.2 Cloud-Konformität
- BES.5.1 Kompetenzen
- BES.5.11 Recht auf Audit
- BES.5.2 Service Level Agreement
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.9 Umgang mit Änderungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.5 Netzverbindungen ab Werk

- BES.8.3 Ressourcensouveränität
- DET.2.1.2 Meldeformulare
- DET.2.1.3 Rückmeldungen
- DET.2.2 Security Operations Center
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.3 Speicherkapazität
- DET.3.4 Revisionssicherheit
- DET.4.1 Überwachung der Protokollierung
- DET.4.12.1 Auslastung des Netzes
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.5 Unerwünschte Datenabflüsse
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.3.1 Autorisierung kritischer Scans
- DET.5.6 Threat Hunting
- DET.5.9 Externe Schwachstellenmeldungen
- DET.6.1.1 Automatisierte Feststellung
- DET.6.1.3 Dokumentation von Ergebnissen
- DET.6.2 Beurteilung von Eingängen
- DET.6.2.1 Dynamische Sandbox-Analyse
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.4 Anhörung
- GC.9.1.1 Externer Austausch zur Informationssicherheit
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.2.2 Brandabschnitte
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.3.1.1 Videoüberwachung
- GEB.3.2 Anmelde- und Empfangsbereiche

- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.8.1.1 Archiv
- GEB.9.4 Überspannungsschutz
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.5.1 Strenge Senderpolicy
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2.1 DNS-Verschlüsselung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.1 Speicherplatzbegrenzung
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.1 Rollen
- NOT.2.1.2 Alarmierung
- NOT.3.1 Wiederanlaufplan
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.11 Datenträgerarchiv
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation

- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- REA.2.2 Automatische Erstreaktion
- REA.2.6.5 Eskalation
- REA.3.1.1 Quantitative Analyse
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.8.4 Begleitung Externer
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise
- TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.3.1.3 Testdaten
- TEST.3.1.4 Testumgebung
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.5.5 Rückblick

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.6 Topologieüberwachung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ARCH.7.3 Entwicklungs- und Testumgebungen
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung

- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.14 Reserve physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.6 Wartung durch Externe
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- BER.2.6 Löschen nach Fristablauf
- BER.3.16 Gruppenkonten - MFA
- BER.3.20 Dienstekonten
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BES.1.4 Outsourcing-Strategie
- BES.1.4.1 Freigabe der Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise

- BES.4.8.2 Cloud-Konformität
- BES.5.1 Kompetenzen
- BES.5.11 Recht auf Audit
- BES.5.2 Service Level Agreement
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.9 Umgang mit Änderungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.5 Netzverbindungen ab Werk
- BES.8.3 Ressourcensouveränität
- DET.2.1.2 Meldeformulare
- DET.2.1.3 Rückmeldungen
- DET.2.2 Security Operations Center
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.3 Speicherkapazität
- DET.3.4 Revisionssicherheit
- DET.4.1 Überwachung der Protokollierung
- DET.4.12.1 Auslastung des Netzes
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.5 Unerwünschte Datenabflüsse
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.3.1 Autorisierung kritischer Scans
- DET.5.6 Threat Hunting
- DET.5.9 Externe Schwachstellenmeldungen
- DET.6.1.1 Automatisierte Feststellung
- DET.6.1.3 Dokumentation von Ergebnissen
- DET.6.2 Beurteilung von Eingängen
- DET.6.2.1 Dynamische Sandbox-Analyse
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster

- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.4 Anhörung
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.2.2 Brandabschnitte
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.3.1.1 Videoüberwachung
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.8.1.1 Archiv
- GEB.9.4 Überspannungsschutz
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.5.1 Strenge Senderpolicy
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2.1 DNS-Verschlüsselung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.14 Code-Signierung im Betriebssystemkern

- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.1 Speicherplatzbegrenzung
- NOT.2.1 Verfahren und Regelungen
 - NOT.2.1.1 Rollen
 - NOT.2.1.2 Alarmierung
- NOT.3.1 Wiederanlaufplan
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.11 Datenträgerarchiv
- NOT.4.5 Archivierung langfristig benötigter Daten
 - NOT.4.5.1 Zum Archiv gehörende Assets
 - NOT.4.5.2 Zum Archiv gehörende Dokumentation
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- REA.2.2 Automatische Erstreaktion
- REA.2.6.5 Eskalation
- REA.3.1.1 Quantitative Analyse
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.8.4 Begleitung Externer
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise
- TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1.1 Dokumentation von Testergebnissen
 - TEST.3.1.3 Testdaten
 - TEST.3.1.4 Testumgebung
- TEST.4.1.1 Unabhängigkeit der Autorisierung
 - TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.5.5 Rückblick

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.9.1.1 Externer Austausch zur Informationssicherheit

Effort level: 5

In der Regel sind für die Umsetzung aufwändige, komplexe Maßnahmen oder eine individuelle Abwägung und Behandlung damit verbundener sekundärer Risiken erforderlich. Hierzu ist häufig tiefgehendes Expertenwissen oder der Einsatz entsprechender externer Dienstleister, sowie eine sorgfältige Planung und Aufrechterhaltung notwendig. Beispiel: Aufbau georedundanter Rechenzentren.

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.3 Mikrosegmentierung
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.7.2 Dedizierte Hardware
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.3.2.1 Software Discovery
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.4 Nachweis des Zugangs
- ASST.6.3 Konformitätsprüfung
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.3 Zugelassene Löschanwendungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.7 IT-System-Zugangskonto

- BER.7.7 Kein Transport privater Schlüssel
- BES.1.3.1 Gesamte Lieferkette
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.4.6.3 Manipulationsschutz
- BES.4.8.1 Zertifizierung
- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.13.1 Datenbereitstellung
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.2.1 Löschverfahren
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.2 Filterung nicht benötigter Inhalte
- DET.4.10 Host-basierte Köder
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.18 Öffentliche Blocklisten
- DET.4.19 Unautorisierte Sendeanlagen

- DET.4.2 Automatische Angriffserkennung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.5.3 Schwachstellenscans
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8 Bedrohungsanalyse
- DET.5.8.1 Auswertung öffentlicher Quellen
- DET.5.9.1 Bonusprogramm
- DEV.4.7 Deterministischer Binärcode
- DLS.2.3 Vollverschlüsselung
- DLS.3.6 Portabilität
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4.1 Niederohmigkeit
- GEB.2.4 Elektromagnetische Abschirmung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.4 Berechtigungsmarkierung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung

- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.2 Staub und Schmutz
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1.6 JavaScript
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.6 Browser-Historie
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.4 Caching
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen

- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1.3 Stabsraum
- NOT.2.1.4 Stabsübung
- NOT.3.2 Geschäftsfortführungsplan
- NOT.3.4 Funktionstest
- NOT.4.12 Georedundanz
- NOT.4.17 Anwendungstest
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.5.2 Innentäter
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.5.3 Forensik-Dienstleister
- REA.2.6.4 Service Level
- SENS.12.1 Hohe Risiken
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering

- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.3 Mikrosegmentierung
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.7.2 Dedizierte Hardware
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.3.2.1 Software Discovery
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.4 Nachweis des Zugangs
- ASST.6.3 Konformitätsprüfung
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.3 Zugelassene Löschanwendungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- BER.7.7 Kein Transport privater Schlüssel

- BES.1.3.1 Gesamte Lieferkette
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.4.6.3 Manipulationsschutz
- BES.4.8.1 Zertifizierung
- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.13.1 Datenbereitstellung
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.2.1 Löschverfahren
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.2 Filterung nicht benötigter Inhalte
- DET.4.10 Host-basierte Köder
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.18 Öffentliche Blocklisten
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.2 Automatische Angriffserkennung

- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.5.3 Schwachstellenscans
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8 Bedrohungsanalyse
- DET.5.8.1 Auswertung öffentlicher Quellen
- DET.5.9.1 Bonusprogramm
- DEV.4.7 Deterministischer Binärkode
- DLS.2.3 Vollverschlüsselung
- DLS.3.6 Portabilität
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4.1 Niederohmigkeit
- GEB.2.4 Elektromagnetische Abschirmung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.4 Berechtigungsmarkierung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.4 Normgerechte Rechenzentren

- GEB.8.2 Staub und Schmutz
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1.6 JavaScript
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.6 Browser-Historie
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.4 Caching
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung

- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1.3 Stabsraum
- NOT.2.1.4 Stabsübung
- NOT.3.2 Geschäftsfortführungsplan
- NOT.3.4 Funktionstest
- NOT.4.12 Georedundanz
- NOT.4.17 Anwendungstest
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.5.2 Innentäter
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.5.3 Forensik-Dienstleister
- REA.2.6.4 Service Level
- SENS.12.1 Hohe Risiken
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung

- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

Namespace: modal_verbs

Definitionen zu Aufwandsstufen

https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/raw/refs/heads/main/Dokumentation/namespaces/effort_level.csv

KANN

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.3 Mikrosegmentierung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.7.2 Dedizierte Hardware
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.3.2.1 Software Discovery
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.4 Nachweis des Zugangs
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.6 Wartung durch Externe
- ASST.6.3 Konformitätsprüfung

- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.21 Notfallzugang
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- BER.7.7 Kein Transport privater Schlüssel
- BES.1.3.1 Gesamte Lieferkette
- BES.1.4 Outsourcing-Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung
- BES.4.6.3 Manipulationsschutz
- BES.4.8.1 Zertifizierung
- BES.4.8.3 IT-Grundschatz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.13.1 Datenbereitstellung
- BES.5.5.1 Datenlokationen
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.2.1 Löschverfahren
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.8.1 Bereithaltung alternativer Lieferanten

- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- DET.2.2 Security Operations Center
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.2 Filterung nicht benötigter Inhalte
- DET.3.5 Unbestreitbarkeit
- DET.4.10 Host-basierte Köder
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.11.2 Netzwerk-Honeypots
- DET.4.11.3 Netzverkehrsfluss
- DET.4.12.1 Auslastung des Netzes
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.18 Öffentliche Blocklisten
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.5 Unerwünschte Datenabflüsse
- DET.4.6 Anomale Nutzung der Anwendung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.3.3 Historische Analyse
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.6 Threat Hunting
- DET.5.7 Analyse verdeckter Kanäle

- DET.5.8.1 Auswertung öffentlicher Quellen
- DET.5.8.1.1 Unautorisierte Publikation
- DET.5.9.1 Bonusprogramm
- DET.6.1.3 Dokumentation von Ergebnissen
- DET.6.2.1 Dynamische Sandbox-Analyse
- DET.6.2.2 Datenträgerschleuse
- DEV.4.7 Deterministischer Binärcode
- DLS.2.3 Vollverschlüsselung
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.6 Portabilität
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4.1 Niederohmigkeit
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.4 Elektromagnetische Abschirmung
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.4 Berechtigungsmarkierung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1.1 Archiv
- GEB.8.2 Staub und Schmutz
- GEB.8.3 Schutz der Datenträger vor Brandschäden

- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1.6 JavaScript
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.6 Browser-Historie
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.4 Caching
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.15 Virtualisierte Browser-Umgebung

- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1.3 Stabsraum
- NOT.2.1.4 Stabsübung
- NOT.3.2 Geschäftsfortführungsplan
- NOT.3.4 Funktionstest
- NOT.4.12 Georedundanz
- NOT.4.17 Anwendungstest
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.2.2 Automatische Erstreaktion
- REA.2.5 IT-Forensik
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.5.3 Forensik-Dienstleister
- REA.2.6.4 Service Level
- SENS.12.1 Hohe Risiken
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.4 Begleitung Externer
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.6 Mitnahme ins Ausland
- TEST.3.1.10 Penetrationstest bei Änderungen

- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.3 Mikrosegmentierung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.7.2 Dedizierte Hardware
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.3.2.1 Software Discovery
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.4 Nachweis des Zugangs
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.6 Wartung durch Externe

- ASST.6.3 Konformitätsprüfung
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.21 Notfallzugang
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- BER.7.7 Kein Transport privater Schlüssel
- BES.1.3.1 Gesamte Lieferkette
- BES.1.4 Outsourcing-Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung
- BES.4.6.3 Manipulationsschutz
- BES.4.8.1 Zertifizierung
- BES.4.8.3 IT-Grundschatz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.13.1 Datenbereitstellung
- BES.5.5.1 Datenlokationen
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.2.1 Lösungsverfahren
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.4.1 Software Bill of Materials (SBOM)

- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- DET.2.2 Security Operations Center
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.2 Filterung nicht benötigter Inhalte
- DET.3.5 Unbestreitbarkeit
- DET.4.10 Host-basierte Köder
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.11.2 Netzwerk-Honeypots
- DET.4.11.3 Netzverkehrsfluss
- DET.4.12.1 Auslastung des Netzes
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.18 Öffentliche Blocklisten
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.5 Unerwünschte Datenabflüsse
- DET.4.6 Anomale Nutzung der Anwendung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.3.3 Historische Analyse
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.6 Threat Hunting

- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8.1 Auswertung öffentlicher Quellen
- DET.5.8.1.1 Unautorisierte Publikation
- DET.5.9.1 Bonusprogramm
- DET.6.1.3 Dokumentation von Ergebnissen
- DET.6.2.1 Dynamische Sandbox-Analyse
- DET.6.2.2 Datenträgerschleuse
- DEV.4.7 Deterministischer Binärcode
- DLS.2.3 Vollverschlüsselung
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.6 Portabilität
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4.1 Niederohmigkeit
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.4 Elektromagnetische Abschirmung
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.4 Berechtigungsmarkierung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1.1 Archiv
- GEB.8.2 Staub und Schmutz

- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1.6 JavaScript
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.6 Browser-Historie
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.4 Caching
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung

- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1.3 Stabsraum
- NOT.2.1.4 Stabsübung
- NOT.3.2 Geschäftsfortführungsplan
- NOT.3.4 Funktionstest
- NOT.4.12 Georedundanz
- NOT.4.17 Anwendungstest
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.2.2 Automatische Erstreaktion
- REA.2.5 IT-Forensik
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.5.3 Forensik-Dienstleister
- REA.2.6.4 Service Level
- SENS.12.1 Hohe Risiken
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.4 Begleitung Externer
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.6 Mitnahme ins Ausland

- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

MUSS

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1 Verfahren und Regelungen
 - ARCH.1.1.1 Dokumentation
 - ARCH.1.1.2 Zuweisung der Aufgaben
 - ARCH.1.1.3 Bekanntgabe
- ARCH.1.2 Regelmäßige Überprüfung
- ASST.1.1 Verfahren und Regelungen
 - ASST.1.1.1 Dokumentation
 - ASST.1.1.2 Zuweisung der Aufgaben
 - ASST.1.1.3 Bekanntgabe
- ASST.1.2 Regelmäßige Überprüfung
- BER.1.1 Verfahren und Regelungen
 - BER.1.1.1 Dokumentation
 - BER.1.1.2 Zuweisung der Aufgaben
 - BER.1.1.3 Bekanntgabe
- BER.1.2 Regelmäßige Überprüfung
- BES.1.1 Verfahren und Regelungen
 - BES.1.1.1 Dokumentation
 - BES.1.1.2 Zuweisung der Aufgaben
 - BES.1.1.3 Bekanntgabe
- BES.1.2 Regelmäßige Überprüfung
- DET.1.1 Verfahren und Regelungen
 - DET.1.1.1 Dokumentation
 - DET.1.1.2 Zuweisung der Aufgaben
 - DET.1.1.3 Bekanntgabe
- DET.1.2 Regelmäßige Überprüfung
- DEV.1.1 Verfahren und Regelungen
 - DEV.1.1.1 Dokumentation
 - DEV.1.1.2 Zuweisung der Aufgaben
 - DEV.1.1.3 Bekanntgabe
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.1 Verfahren und Regelungen
 - DLS.1.1.1 Dokumentation
 - DLS.1.1.2 Zuweisung der Aufgaben
 - DLS.1.1.3 Bekanntgabe
- DLS.1.2 Regelmäßige Überprüfung

- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.10.1 Festlegung von Vorgehensweisen
- GC.10.2 Freigabe von Vorgehensweisen
- GC.11.1 Methodik für das Risikomanagement
- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.2 Verpflichtung der Institutionsleitung
- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.6.1.4 Freigabe der Sicherheitsleitlinie
- GC.7.1 Verfahren und Regelungen
- GC.8.1 Verfahren zur Ressourcenplanung
- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.8.1.2 Stellvertreterregelungen
- GC.8.1.3 Vermeidung von Interessenkonflikten
- GC.8.1.4 Festlegung einer Sicherheitsorganisation
- GC.8.1.5 Sicherstellung der Qualifikation
- GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
- GC.9.1.2 Kommunikation im Projektmanagement
- GC.9.1.3 Dokumentenlenkung
- GEB.1.1 Verfahren und Regelungen
- GEB.1.1.1 Dokumentation
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.3 Bekanntgabe
- GEB.1.2 Regelmäßige Überprüfung
- KONF.1.1 Verfahren und Regelungen
- KONF.1.1.1 Dokumentation
- KONF.1.1.2 Zuweisung der Aufgaben

- KONF.1.1.3 Bekanntgabe
- KONF.1.2 Regelmäßige Überprüfung
- NOT.1.1 Verfahren und Regelungen
 - NOT.1.1.1 Dokumentation
 - NOT.1.1.2 Zuweisung der Aufgaben
 - NOT.1.1.3 Bekanntgabe
- NOT.1.2 Regelmäßige Überprüfung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
 - PERF.3.1.2 Planen von internen Audits
 - PERF.3.1.3 Auswahl des Auditteams
 - PERF.3.1.4 Umfang von Audits
- PERF.4.1 Dokumentation von Auditergebnissen
 - PERF.4.1.2 Kommunikation an Stakeholder
- PERF.5.1 Eignungsprüfung
 - PERF.5.1.9 Maßnahmenvorschläge
- PERF.5.2 Bericht an die Institutionsleitung
- PERF.6.1 Sicherheitsvorfälle
 - PERF.6.1.1 Sicherheitsvorfälle
 - PERF.6.1.2 Schwachstellen
 - PERF.6.1.3 Bedrohungen
- PERF.7.1 Aktualität der Anforderungen
- PERS.1.1 Verfahren und Regelungen
 - PERS.1.1.1 Dokumentation
 - PERS.1.1.2 Zuweisung der Aufgaben
 - PERS.1.1.3 Bekanntgabe
- PERS.1.2 Regelmäßige Überprüfung
- REA.1.1 Verfahren und Regelungen
 - REA.1.1.1 Dokumentation
 - REA.1.1.2 Zuweisung der Aufgaben
 - REA.1.1.3 Bekanntgabe
- REA.1.2 Regelmäßige Überprüfung
- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.3 Risikoeigentümer
- RISK.1.5 Freigabe des Risikomanagements
- SENS.1.1 Verfahren und Regelungen
 - SENS.1.1.1 Dokumentation

- SENS.1.1.2 Zuweisung der Aufgaben
- SENS.1.1.3 Bekanntgabe
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes
- STM.4.1 Erfassung relevanter Assets
- STM.4.2 Dokumentation relevanter Assets
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- TEST.1.1 Verfahren und Regelungen
- TEST.1.1.1 Dokumentation
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.3 Bekanntgabe
- TEST.1.2 Regelmäßige Überprüfung
- UMS.1.1 Ermittlung des Umsetzungsstatus
- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.5.1 Autorisierung von Ausnahmen
- UMS.5.2 Dokumentation von Ausnahmen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen

- VRB.4.2 Verbesserungsmaßnahmen
- VRB.5.1 Priorisierung von Maßnahmen
- VRB.6.1 Wirksamkeitsprüfung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1 Verfahren und Regelungen
 - ARCH.1.1.1 Dokumentation
 - ARCH.1.1.2 Zuweisung der Aufgaben
 - ARCH.1.1.3 Bekanntgabe
- ARCH.1.2 Regelmäßige Überprüfung
- ASST.1.1 Verfahren und Regelungen
 - ASST.1.1.1 Dokumentation
 - ASST.1.1.2 Zuweisung der Aufgaben
 - ASST.1.1.3 Bekanntgabe
- ASST.1.2 Regelmäßige Überprüfung
- BER.1.1 Verfahren und Regelungen
 - BER.1.1.1 Dokumentation
 - BER.1.1.2 Zuweisung der Aufgaben
 - BER.1.1.3 Bekanntgabe
- BER.1.2 Regelmäßige Überprüfung
- BES.1.1 Verfahren und Regelungen
 - BES.1.1.1 Dokumentation
 - BES.1.1.2 Zuweisung der Aufgaben
 - BES.1.1.3 Bekanntgabe
- BES.1.2 Regelmäßige Überprüfung
- DET.1.1 Verfahren und Regelungen
 - DET.1.1.1 Dokumentation
 - DET.1.1.2 Zuweisung der Aufgaben
 - DET.1.1.3 Bekanntgabe
- DET.1.2 Regelmäßige Überprüfung
- DEV.1.1 Verfahren und Regelungen
 - DEV.1.1.1 Dokumentation
 - DEV.1.1.2 Zuweisung der Aufgaben
 - DEV.1.1.3 Bekanntgabe
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.1 Verfahren und Regelungen
 - DLS.1.1.1 Dokumentation

- DLS.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.3 Bekanntgabe
- DLS.1.2 Regelmäßige Überprüfung
- GEB.1.1 Verfahren und Regelungen
- GEB.1.1.1 Dokumentation
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.3 Bekanntgabe
- GEB.1.2 Regelmäßige Überprüfung
- KONF.1.1 Verfahren und Regelungen
- KONF.1.1.1 Dokumentation
- KONF.1.1.2 Zuweisung der Aufgaben
- KONF.1.1.3 Bekanntgabe
- KONF.1.2 Regelmäßige Überprüfung
- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.1 Dokumentation
- NOT.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.3 Bekanntgabe
- NOT.1.2 Regelmäßige Überprüfung
- PERS.1.1 Verfahren und Regelungen
- PERS.1.1.1 Dokumentation
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.1.1.3 Bekanntgabe
- PERS.1.2 Regelmäßige Überprüfung
- REA.1.1 Verfahren und Regelungen
- REA.1.1.1 Dokumentation
- REA.1.1.2 Zuweisung der Aufgaben
- REA.1.1.3 Bekanntgabe
- REA.1.2 Regelmäßige Überprüfung
- SENS.1.1 Verfahren und Regelungen
- SENS.1.1.1 Dokumentation
- SENS.1.1.2 Zuweisung der Aufgaben
- SENS.1.1.3 Bekanntgabe
- TEST.1.1 Verfahren und Regelungen
- TEST.1.1.1 Dokumentation
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.3 Bekanntgabe
- TEST.1.2 Regelmäßige Überprüfung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.10.1 Festlegung von Vorgehensweisen
- GC.10.2 Freigabe von Vorgehensweisen
- GC.11.1 Methodik für das Risikomanagement
- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.2 Verpflichtung der Institutionsleitung
- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.6.1.4 Freigabe der Sicherheitsleitlinie
- GC.7.1 Verfahren und Regelungen
- GC.8.1 Verfahren zur Ressourcenplanung
- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.8.1.2 Stellvertreterregelungen
- GC.8.1.3 Vermeidung von Interessenkonflikten
- GC.8.1.4 Festlegung einer Sicherheitsorganisation
- GC.8.1.5 Sicherstellung der Qualifikation
- GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
- GC.9.1.2 Kommunikation im Projektmanagement
- GC.9.1.3 Dokumentenlenkung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
- PERF.3.1.2 Planen von internen Audits
- PERF.3.1.3 Auswahl des Auditteams
- PERF.3.1.4 Umfang von Audits
- PERF.4.1 Dokumentation von Auditergebnissen

- PERF.4.1.2 Kommunikation an Stakeholder
- PERF.5.1 Eignungsprüfung
- PERF.5.1.9 Maßnahmenvorschläge
- PERF.5.2 Bericht an die Institutionsleitung
- PERF.6.1 Sicherheitsvorfälle
- PERF.6.1.1 Sicherheitsvorfälle
- PERF.6.1.2 Schwachstellen
- PERF.6.1.3 Bedrohungen
- PERF.7.1 Aktualität der Anforderungen
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes
- STM.4.1 Erfassung relevanter Assets
- STM.4.2 Dokumentation relevanter Assets
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- UMS.1.1 Ermittlung des Umsetzungsstatus
- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.5.1 Autorisierung von Ausnahmen
- UMS.5.2 Dokumentation von Ausnahmen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS

- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen
- VRB.5.1 Priorisierung von Maßnahmen
- VRB.6.1 Wirksamkeitsprüfung

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.2 Einhaltung der BSI-Kriterien
- RISK.1.3 Risikoeigentümer
- RISK.1.4 Risikoappetit
- RISK.1.5 Freigabe des Risikomanagements
- RISK.1.6 Kritikalitätskriterien für Geschäftsprozesse
- RISK.1.7 Kriterien für die Risikobeurteilung
- RISK.1.8 Kriterien für die Risikoakzeptanz

SOLLTE

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.2 Gastnetz
 - ARCH.2.2.3 Segmentierung von Servern und Clients
 - ARCH.2.2.5 OT-Systeme
 - ARCH.2.2.6 Demilitarisierte Zone
 - ARCH.2.2.7 Management-Netz
 - ARCH.2.2.8 Segmentierung von Test und Betrieb
 - ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.2.6 Topologieüberwachung
- ARCH.3.1 Netzabdeckung
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.4.1 Netzzugangskontrolle
 - ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
 - ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
 - ARCH.5.1.10 Webfilterung
 - ARCH.5.1.10.1 Bekannte schädliche Inhalte
 - ARCH.5.1.10.2 Bekannte illegale Inhalte
 - ARCH.5.1.10.3 Speicherdienste
 - ARCH.5.1.11 P-A-P-Struktur
 - ARCH.5.1.2 Netzbasierte Angriffe
 - ARCH.5.1.3 TCP-basierte Angriffe
 - ARCH.5.1.4 UDP-basierte Angriffe
 - ARCH.5.1.5 Deaktivierung von Split Tunneling
 - ARCH.5.1.6 Blockieren direkter Management-Verbindungen
 - ARCH.5.1.7 Edge-Routing
 - ARCH.5.1.8 Inspektion verschlüsselter Verbindungen

- ARCH.5.1.9 Filterung von DNS
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.3 Entwicklungs- und Testumgebungen
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.2.1 Inventar der Informationen
- ASST.2.1.1 Informationsverantwortung
- ASST.2.2 Inventar der Systeme
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.2.3 Inventar der Anwendungen
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.2.4 Klassifizierung
- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelter Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen

- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.3 Geregeltes Löschen oder Vernichten
 - ASST.7.3.1 Standardisierte Vernichtung
 - ASST.7.3.2 Löschverfahren
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.2 Einschränkung
- BER.2.3 Stammdatenprüfung
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.2.5 Deaktivierung bei Weggang
- BER.2.6 Löschen nach Fristablauf
- BER.3.1 Zentrales Management
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.15 Keine Gruppenkonten
- BER.3.16 Gruppenkonten - MFA
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.2 Einschränkung des Managements
- BER.3.20 Dienstkonten
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.3.3 Protokollierung von Änderungen
- BER.3.4 Identität-Zugangskonto
- BER.3.5 Privilegierte Zugangskonten
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.4.1 Identitätsüberprüfung
- BER.5.1 Prinzip der geringsten Berechtigungen
 - BER.5.1.1 Rollenbasierte Berechtigung
 - BER.5.2 Begründung von Berechtigungen

- BER.5.3 Überprüfung von Berechtigungen
 - BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.5.8 Entzug von Berechtigungen
- BER.6.1 Passwortmanager
- BER.6.10 Monitoring von Zugangsdaten
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
 - BER.7.10 Abgelaufene Schlüssel
 - BER.7.11 Integrität
 - BER.7.12 Authentizität
 - BER.7.13 Gültigkeit
 - BER.7.14 Schlüssel vor Ablauf prüfen
 - BER.7.15 Vorgehensweise nach Nutzung
 - BER.7.16 Vorgaben für die Schlüsselbeglaubigung
 - BER.7.16.1 Zertifizierungsstelle
 - BER.7.16.2 Beglaubigung
 - BER.7.16.3 Erneuerung
 - BER.7.16.4 Revocation
 - BER.7.16.5 Beglaubigungsstatus
 - BER.7.16.6 Revocationstatus
- BER.7.2 Schlüssellänge
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis

- BES.1.4.1 Freigabe der Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.1 Erfassung des Bedarfes
 - BES.2.1.1 Verwendungszweck
 - BES.2.1.3 Systemvoraussetzungen
 - BES.2.1.4 Kompatibilität
 - BES.2.1.4.1 Kompatibilität der Schnittstellen
 - BES.2.1.4.2 Kompatibilität der Netzanbindung
 - BES.2.1.4.3 Kompatibilität des Administrationsmodells
 - BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
 - BES.2.1.5 Lizenzierung
 - BES.2.1.6 Support- und Wartungsverträge
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.4.5 Security by Design
- BES.4.6 Security by Default
 - BES.4.6.1 Authentifizierung des Kunden
 - BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
 - BES.4.8.2 Cloud-Konformität
- BES.5.1 Kompetenzen
- BES.5.10 Behandlung von Vorfällen
 - BES.5.10.1 Erreichbarkeit über Meldewege
 - BES.5.10.2 Melden von Vorfällen
 - BES.5.10.3 Schwachstellenbehebung
- BES.5.11 Recht auf Audit
- BES.5.12 Informationspflichten

- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5 Nutzungsregelungen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.3 Übertragbarkeit von Daten
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.10 Serviceprofil
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.5 Netzverbindungen ab Werk
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.2.1.2 Meldeformulare
- DET.2.1.3 Rückmeldungen
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.1 Authentifizierungen

- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.3.3 Speicherkapazität
- DET.3.4 Revisionssicherheit
- DET.4.1 Überwachung der Protokollierung
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.2 Automatische Angriffserkennung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.2 Schwachstellenregister
- DET.5.3 Schwachstellenscans
- DET.5.3.1 Autorisierung kritischer Scans
- DET.5.8 Bedrohungsanalyse
- DET.5.9 Externe Schwachstellenmeldungen
- DET.6.1 Beurteilung von Ereignissen
- DET.6.1.1 Automatisierte Feststellung
- DET.6.1.2 Automatische Alarmierung
- DET.6.2 Beurteilung von Eingängen
- DEV.2.1 Security by Design Architektur
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.2.6.1 Eingabevalidierung

- DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.2 Bibliotheksquellen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- DEV.4.8 Default-Zugangsdaten
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung
- DEV.7.2 Zertifikatsmonitoring
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.2.2 Transportverschlüsselung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.4 Anhörung
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.4.1 Dekommissionierung
- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren
- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- GC.7.1.4 Prävention von Verstößen
- GC.9.1.1 Externer Austausch zur Informationssicherheit
- GEB.1.3 Autorisierung von Standorten
- GEB.1.3.1 Abnahme von Standorten

- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.1.2 Klimamessung
- GEB.10.2 Brandschutz
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.3 Wasserschutz
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.2.1 Installation von Perimetern
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.3 Besucheranmeldung
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.7.3 Schlüsselaudit
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung
- KONF.1.3 Management von Werkzeugen
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation

- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.2 Warteraum
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1 Eingabevalidierung
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.1.9 Journaling
- KONF.12.10 Cookie-Attribute
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- KONF.12.14 DNS-Falschinformationen
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.7 Erweiterte Attribute

- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
 - KONF.13.1.1 SPAM-Filter
 - KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
 - KONF.13.2.1 Verifikation der Sendeberechtigung
 - KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.5 Publikation der Sendeberechtigung
 - KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.1 Verschlüsselung beim Transport
 - KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.2.1 Grundkonfiguration für Systeme
 - KONF.2.1.1 Versionierung der Systemkonfiguration
 - KONF.2.2 Kryptographische Verfahren in IT-Systemen
 - KONF.2.3 Änderung von Default-Zugangsdaten
 - KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
 - KONF.2.4.1 Nicht benötigte Zertifikate
 - KONF.2.4.2 Externe Cloud-Anbindungen
 - KONF.2.5 Überprüfung der Konfiguration
 - KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
 - KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2 DNS-Anbindung
 - KONF.4.2.1 DNS-Verschlüsselung

- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.14 Browser Sandboxing
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.8.2 Automatische Updates der Anwendung
- KONF.9.1 Speicherplatzbegrenzung
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.1 Rollen
- NOT.2.1.2 Alarmierung
- NOT.3.1 Wiederanlaufplan
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall

- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.1 Dokumentation der Quellen
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.11 Datenträgerarchiv
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung
- NOT.4.9 Speichermedien
- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung

- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.2.4 Zuständigkeiten
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.4 Stellenbeschreibungen
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung
- REA.2.1 Triage und Erstreaktion
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6 Ursachenanalyse und Behandlung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.2.6.5 Eskalation
- REA.3.1 Verbesserung durch Erkenntnisse
- REA.3.1.1 Quantitative Analyse
- SENS.1.2 Erfolgsmessung
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung

- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.2.1 Schutzziele
- SENS.2.2 Meldewege
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.

- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.5 Verwahrung Intern
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.3 Verwahrung außer Haus
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.1 Versionshistorie
- TEST.2.2 Folgenabschätzung
 - TEST.2.2.1 Kategorisierung von Änderungen
 - TEST.2.2.2 Anpassung der Dokumentation
 - TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1 Sicherheitstest
 - TEST.3.1.1 Dokumentation von Testergebnissen
 - TEST.3.1.2 Integritätstest
 - TEST.3.1.3 Testdaten
 - TEST.3.1.4 Testumgebung

- TEST.3.2 Testabdeckung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- TEST.5.1 Information betroffener Kreise
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.4 Persistenz
- TEST.5.5 Rückblick
- UMS.2.1 Bewertung des Restrisikos
- VRB.2.2 Anpassung des ISMS
- VRB.3.1 Identifikation von Verbesserungspotenzialen
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
- ARCH.2.2.1 Externe Netzanschlüsse
- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.2.6 Topologieüberwachung
- ARCH.3.1 Netzabdeckung
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.2 Autorisiertes Routing

- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
 - ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
 - ARCH.5.1.10 Webfilterung
 - ARCH.5.1.10.1 Bekannte schädliche Inhalte
 - ARCH.5.1.10.2 Bekannte illegale Inhalte
 - ARCH.5.1.10.3 Speicherdienste
 - ARCH.5.1.11 P-A-P-Struktur
 - ARCH.5.1.2 Netzbasierte Angriffe
 - ARCH.5.1.3 TCP-basierte Angriffe
 - ARCH.5.1.4 UDP-basierte Angriffe
 - ARCH.5.1.5 Deaktivierung von Split Tunneling
 - ARCH.5.1.6 Blockieren direkter Management-Verbindungen
 - ARCH.5.1.7 Edge-Routing
 - ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
 - ARCH.5.1.9 Filterung von DNS
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.3 Entwicklungs- und Testumgebungen
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.2.1 Inventar der Informationen
 - ASST.2.1.1 Informationsverantwortung
- ASST.2.2 Inventar der Systeme
 - ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.2.3 Inventar der Anwendungen
 - ASST.2.3.1 Autorisierung von Anwendungen
 - ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.2.4 Klassifizierung
- ASST.3.1 Nutzungsvereinbarungen
 - ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
 - ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets

- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelte Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.3 Geregeltes Löschen oder Vernichten
 - ASST.7.3.1 Standardisierte Vernichtung
 - ASST.7.3.2 Löschverfahren
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.2 Einschränkung
- BER.2.3 Stammdatenprüfung
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.2.5 Deaktivierung bei Weggang
- BER.2.6 Löschen nach Fristablauf
- BER.3.1 Zentrales Management
 - BER.3.10 Anmeldeversuchsgrenze an der Anwendung
 - BER.3.11 Systemsperre bei Inaktivität
 - BER.3.12 Sperre der Anwendung bei Inaktivität
 - BER.3.13 Zugang löschen nach Fristablauf
 - BER.3.15 Keine Gruppenkonten
 - BER.3.16 Gruppenkonten - MFA
 - BER.3.17 Gruppenkonten - Wechsel dokumentieren
 - BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang

- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.2 Einschränkung des Managements
- BER.3.20 Dienstekonten
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.3.3 Protokollierung von Änderungen
- BER.3.4 Identität-Zugangskonto
- BER.3.5 Privilegierte Zugangskonten
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.4.1 Identitätsüberprüfung
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.2 Begründung von Berechtigungen
- BER.5.3 Überprüfung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.5.8 Entzug von Berechtigungen
- BER.6.1 Passwortmanager
- BER.6.10 Monitoring von Zugangsdaten
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.15 Vorgehensweise nach Nutzung

- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.2 Schlüssellänge
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.4.1 Freigabe der Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.1 Erfassung des Bedarfes
- BES.2.1.1 Verwendungszweck
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.4 Kompatibilität
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien

- BES.4.4 Vertragsvorlage für Outsourcing
- BES.4.5 Security by Design
- BES.4.6 Security by Default
- BES.4.6.1 Authentifizierung des Kunden
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
- BES.4.8.2 Cloud-Konformität
- BES.5.1 Kompetenzen
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.11 Recht auf Audit
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5 Nutzungsregelungen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.3 Übertragbarkeit von Daten
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur

- BES.7.4.10 Serviceprofil
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.5 Netzverbindungen ab Werk
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.2.1.2 Meldeformulare
- DET.2.1.3 Rückmeldungen
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.3.3 Speicherkapazität
- DET.3.4 Revisionssicherheit
- DET.4.1 Überwachung der Protokollierung
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.2 Automatische Angriffserkennung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.2 Schwachstellenregister

- DET.5.3 Schwachstellenscans
- DET.5.3.1 Autorisierung kritischer Scans
- DET.5.8 Bedrohungsanalyse
- DET.5.9 Externe Schwachstellenmeldungen
- DET.6.1 Beurteilung von Ereignissen
- DET.6.1.1 Automatisierte Feststellung
- DET.6.1.2 Automatische Alarmierung
- DET.6.2 Beurteilung von Eingängen
- DEV.2.1 Security by Design Architektur
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.2.6.1 Eingabvalidierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.2 Bibliotheksquellen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- DEV.4.8 Default-Zugangsdaten
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung
- DEV.7.2 Zertifikatsmonitoring
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.2.2 Transportverschlüsselung

- DLS.3.1 Einhaltung der Sicherheitsvorgaben
 - DLS.3.1.1 Audit oder Zertifikat
- DLS.3.4 Anhörung
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.4.1 Dekommissionierung
 - DLS.4.1.1 Unabhängigkeit
 - DLS.4.1.2 Berechtigungen deaktivieren
- GEB.1.3 Autorisierung von Standorten
 - GEB.1.3.1 Abnahme von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
 - GEB.10.1.2 Klimamessung
- GEB.10.2 Brandschutz
 - GEB.10.2.1 Baulicher Brandschutz
 - GEB.10.2.2 Brandabschnitte
 - GEB.10.2.5 Vermeidung von Brandlasten
 - GEB.10.2.6 Brandmeldeanlagen
 - GEB.10.2.8 Brandschutzprüfung
- GEB.10.3 Wasserschutz
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.2.1 Installation von Perimetern
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.3.1 Überwachung von Zutrittspunkten
 - GEB.3.2 Anmelde- und Empfangsbereiche
 - GEB.3.3 Authentifizierung vor Zutritt
 - GEB.3.3.3 Besucheranmeldung
 - GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
 - GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.2 Verwahrung von Schlüsseln

- GEB.7.3 Schlüsselaudit
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung
- KONF.1.3 Management von Werkzeugen
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.2 Warteraum
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1 Eingabevalidierung
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.1.9 Journaling

- KONF.12.10 Cookie-Attribute
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- KONF.12.14 DNS-Falschinformationen
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung

- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2 DNS-Anbindung
- KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.14 Browser Sandboxing
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.9 Einschränkung der Installation

- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.8.2 Automatische Updates der Anwendung
- KONF.9.1 Speicherplatzbegrenzung
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.1 Rollen
- NOT.2.1.2 Alarmierung
- NOT.3.1 Wiederanlaufplan
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.1 Dokumentation der Quellen
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.11 Datenträgerarchiv
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung
- NOT.4.9 Speichermedien
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.2.4 Zuständigkeiten
- PERS.3.1 Dienst- oder Arbeitsvertrag

- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.4 Stellenbeschreibungen
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung
- REA.2.1 Triage und Erstreaktion
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6 Ursachenanalyse und Behandlung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.2.6.5 Eskalation
- REA.3.1 Verbesserung durch Erkenntnisse
- REA.3.1.1 Quantitative Analyse
- SENS.1.2 Erfolgsmessung
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.2.1 Schutzziele
- SENS.2.2 Meldewege

- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.4 Nutzung unauthorisierter Assets
- SENS.2.4.1 Verbindung unauthorisierter IT-Systeme
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation

- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.5 Verwahrung Intern
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.3 Verwahrung außer Haus
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.1 Versionshistorie
- TEST.2.2 Folgenabschätzung
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.2.2.2 Anpassung der Dokumentation
- TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1 Sicherheitstest
- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.3.1.2 Integritätstest
- TEST.3.1.3 Testdaten
- TEST.3.1.4 Testumgebung
- TEST.3.2 Testabdeckung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen

- TEST.5.1 Information betroffener Kreise
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.4 Persistenz
- TEST.5.5 Rückblick

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- GC.7.1.4 Prävention von Verstößen
- GC.9.1.1 Externer Austausch zur Informationssicherheit
- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- UMS.2.1 Bewertung des Restrisikos
- VRB.2.2 Anpassung des ISMS
- VRB.3.1 Identifikation von Verbesserungspotenzialen
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.9 Bestätigung des Restrisikos

Namespace: result

Definitionen zu sonstigen in Anforderungen verwendeten Begriffen <https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/raw/refs/heads/main/Dokumentation/namespaces/result.csv>

Alarmierung

BSI/Grundschrift/Anwenderkatalog/Grundschrift++

- DET.6.1.2 Automatische Alarmierung
- NOT.2.1.2 Alarmierung

BSI/Grundschrift/Quellkataloge/Kernel

- DET.6.1.2 Automatische Alarmierung
- NOT.2.1.2 Alarmierung

Anforderung

BSI/Grundschrift/Anwenderkatalog/Grundschrift++

- ASST.6.3 Konformitätsprüfung
- GC.8.1.5 Sicherstellung der Qualifikation
- PERF.7.1 Aktualität der Anforderungen
- PERS.2.3.3 Rollentrennung - Audits
- STM.2.1 Erstellung eines Anforderungspakets
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- TEST.3.1 Sicherheitstest
- UMS.2.1 Bewertung des Restrisikos
- UMS.3.1 Umsetzungsplanung
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen

BSI/Grundschrift/Quellkataloge/Kernel

- ASST.6.3 Konformitätsprüfung

- PERS.2.3.3 Rollentrennung - Audits
- TEST.3.1 Sicherheitstest

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.8.1.5 Sicherstellung der Qualifikation
- PERF.7.1 Aktualität der Anforderungen
- STM.2.1 Erstellung eines Anforderungspakets
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- UMS.2.1 Bewertung des Restrisikos
- UMS.3.1 Umsetzungsplanung
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen

Asset

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.1.1 Verfahren und Regelungen
- ASST.2.1 Inventar der Informationen
- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.6 Autorisierung von Veräußerungen
- BES.5.5 Nutzungsregelungen
- BES.6.6 Rückgewähr von Assets
- GEB.1.3 Autorisierung von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- NOT.4.5.1 Zum Archiv gehörende Assets
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.8.6 Rückgabe nicht mehr benötigter Assets

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.1.1 Verfahren und Regelungen
- ASST.2.1 Inventar der Informationen
- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.6 Autorisierung von Veräußerungen
- BES.5.5 Nutzungsregelungen
- BES.6.6 Rückgewähr von Assets
- GEB.1.3 Autorisierung von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- NOT.4.5.1 Zum Archiv gehörende Assets
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.8.6 Rückgabe nicht mehr benötigter Assets

Authentizität

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.7.12 Authentizität
- KONF.13.2 Authentizität von Nachrichten

BSI/Grundschutz/Quellkataloge/Kernel

- BER.7.12 Authentizität
- KONF.13.2 Authentizität von Nachrichten

Autorisierung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.9.1 Autorisierung von Änderungen

BSI/Grundschutz/Quellkataloge/Kernel

- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.9.1 Autorisierung von Änderungen

Biometrie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.6.3 Deaktivierung einfacher Biometrie

BSI/Grundschutz/Quellkataloge/Kernel

- BER.6.3 Deaktivierung einfacher Biometrie

Elementare Gefährdungen

Keine Controls gefunden.

Gefährdung (englisch "applied threat")

Keine Controls gefunden.

Geschäftsprozess

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.2.1.2 Geschäftsprozessprofile
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- NOT.3.2 Geschäftsfortführungsplan
- SENS.11.1 Sensibilisierung der Institutionsleitung

BSI/Grundschutz/Quellkataloge/Kernel

- BES.2.1.2 Geschäftsprozessprofile
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- NOT.3.2 Geschäftsfortführungsplan
- SENS.11.1 Sensibilisierung der Institutionsleitung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.6 Kritikalitätskriterien für Geschäftsprozesse

Institutionen

Keine Controls gefunden.

Integrität

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.7.11 Integrität
- DET.5.10.4 Integritätsprüfung von Patches
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.5.3 Integritätsprüfung
- TEST.3.1.2 Integritätstest

BSI/Grundschutz/Quellkataloge/Kernel

- BER.7.11 Integrität
- DET.5.10.4 Integritätsprüfung von Patches

- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.5.3 Integritätsprüfung
- TEST.3.1.2 Integritätstest

Kompetenz

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.5.1 Kompetenzen

BSI/Grundschutz/Quellkataloge/Kernel

- BES.5.1 Kompetenzen

Korrekturmaßnahme

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- VRB.4.1 Korrekturmaßnahmen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- VRB.4.1 Korrekturmaßnahmen

Maßnahme / Schutzmaßnahme

Keine Controls gefunden.

Praktik

Keine Controls gefunden.

Redundanz

Keine Controls gefunden.

Schwachstelle (englisch "vulnerability")

Keine Controls gefunden.

Sicherheitskritisches Ereignis

Keine Controls gefunden.

Sicherheitsrelevantes Ereignis

Keine Controls gefunden.

Sicherheitsvorfall

Keine Controls gefunden.

Verfügbarkeit

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.5.5 Wartungsfenster
- DET.4.12 Monitoring der Netzverfügbarkeit

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.5.5 Wartungsfenster
- DET.4.12 Monitoring der Netzverfügbarkeit

Vertraulichkeit

Keine Controls gefunden.

Zielobjekt

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DLS.3.4 Anhörung
- SENS.7.1 Spezifische Sensibilisierung

BSI/Grundschutz/Quellkataloge/Kernel

- DLS.3.4 Anhörung
- SENS.7.1 Spezifische Sensibilisierung

Zielobjektkategorie

Keine Controls gefunden.

Zugang

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.11 Physische Segmentierung
- ASST.4.4 Nachweis des Zugangs
- BER.3.1 Zentrales Management
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.2 Einschränkung des Managements
- BER.3.20 Dienstkonten
- BER.3.21 Notfallzugang
- BER.3.3 Protokollierung von Änderungen
- BER.3.5 Privilegierte Zugangskonten
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.6.10 Monitoring von Zugangsdaten
- BES.6.1 Entziehung der Zugangsberechtigungen
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DEV.4.8 Default-Zugangsdaten
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.5.2 Keine Mehrfachanmeldung
- SENS.4.1.1 Verdeckte Eingabe
- SENS.7.25 Zugang zum Fahrzeug

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.11 Physische Segmentierung

- ASST.4.4 Nachweis des Zugangs
- BER.3.1 Zentrales Management
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.2 Einschränkung des Managements
- BER.3.20 Dienstkonten
- BER.3.21 Notfallzugang
- BER.3.3 Protokollierung von Änderungen
- BER.3.5 Privilegierte Zugangskonten
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.6.10 Monitoring von Zugangsdaten
- BES.6.1 Entziehung der Zugangsberechtigungen
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DEV.4.8 Default-Zugangsdaten
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.5.2 Keine Mehrfachanmeldung
- SENS.4.1.1 Verdeckte Eingabe
- SENS.7.25 Zugang zum Fahrzeug

Zugangskonto

Keine Controls gefunden.

Zugriff

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.5.1.10 Webfilterung

- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.5.1.2 JIT--JEA-Berechtigungen
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- GEB.6.2 Geschützte Aufstellung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.9 Zugriff auf Code
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- SENS.10.5 Systemadministration - Internetnutzung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.5.1.10 Webfilterung
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.5.1.2 JIT--JEA-Berechtigungen
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- GEB.6.2 Geschützte Aufstellung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.9 Zugriff auf Code

- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- SENS.10.5 Systemadministration - Internetnutzung

Zutritt

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.4.2 Gesonderte Autorisierung

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.4.2 Gesonderte Autorisierung

Namespace: tags

Definitionen zu Schlagwörtern oder thematischen Labels

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/raw/refs/heads/main/Dokumentation/namespaces/tags.csv>

Advanced Persistent Threat (APT)

Keine Controls gefunden.

Advanced Persistent Threats (APT)

Keine Controls gefunden.

Archivierung

Keine Controls gefunden.

Auslandsreisen

Keine Controls gefunden.

Authentication and Authorization

Keine Controls gefunden.

Automatic Session Locking

Keine Controls gefunden.

Automatische Sicherheitsrichtlinie

Keine Controls gefunden.

BCM

Keine Controls gefunden.

Bring Your Own Device

Keine Controls gefunden.

Brute Force Angriffe

Keine Controls gefunden.

Brute-Force-Attacke

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- KONF.11.5 Erraten von Zugriffslinks

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- KONF.11.5 Erraten von Zugriffslinks

Change Management

Keine Controls gefunden.

Command & Control

Keine Controls gefunden.

Compliance Management

Keine Controls gefunden.

Compliance-Management

Keine Controls gefunden.

Credential Stuffing

Keine Controls gefunden.

Cryptography

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.6.8 Kriterien für die Qualität von Passwörtern
- DEV.3.4 Passwort-Hashing
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.4.2.1 DNS-Verschlüsselung

BSI/Grundschutz/Quellkataloge/Kernel

- BER.6.8 Kriterien für die Qualität von Passwörtern
- DEV.3.4 Passwort-Hashing
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.4.2.1 DNS-Verschlüsselung

Data Exfiltration

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.11 Anomalien in Netzen und am Perimeter

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.11 Anomalien in Netzen und am Perimeter

Data Leak

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.6.10 Auflistung von Verzeichnisinhalten

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.6.10 Auflistung von Verzeichnisinhalten

DDoS

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe

Defense-in-depth

Keine Controls gefunden.

Denial of Service

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service

Error Handling

Keine Controls gefunden.

Exit-Strategie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Löschverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.3.6 Portabilität
- DLS.4.1 Dekommissionierung
- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren

BSI/Grundschutz/Quellkataloge/Kernel

- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Löschverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.3.6 Portabilität
- DLS.4.1 Dekommissionierung
- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren

Failover

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.3 Redundante Server

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.3 Redundante Server

Führungsverantwortung

Keine Controls gefunden.

Hochverfügbarkeit

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.15.4 Überbuchung von virtualisierten Ressourcen

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.15.4 Überbuchung von virtualisierten Ressourcen

Honeypot

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.10 Host-basierte Köder
- DET.4.11.2 Netzwerk-Honeypots

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.10 Host-basierte Köder
- DET.4.11.2 Netzwerk-Honeypots

Insider Threat

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- SENS.2.4 Nutzung unauthorisierter Assets
- SENS.2.4.1 Verbindung unauthorisierter IT-Systeme

BSI/Grundschutz/Quellkataloge/Kernel

- SENS.2.4 Nutzung unauthorisierter Assets
- SENS.2.4.1 Verbindung unauthorisierter IT-Systeme

Inspektion

Keine Controls gefunden.

Internet Exposure

Keine Controls gefunden.

Inventories

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.7.1.1 Gesetzliche Verpflichtungen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.7.1.1 Gesetzliche Verpflichtungen

Kompetenzmanagement

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.5.1 Kompetenzen
- BES.5.7 Schulung
- PERS.6.1 Vorgehensweise für den Weggang

BSI/Grundschutz/Quellkataloge/Kernel

- BES.5.1 Kompetenzen
- BES.5.7 Schulung
- PERS.6.1 Vorgehensweise für den Weggang

Kontakt mit Behörden

Keine Controls gefunden.

Langzeitarchivierung

Keine Controls gefunden.

Lateral Movement

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.3 Mikrosegmentierung
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.3 Mikrosegmentierung
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung

Lieferketten

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.4.3 Softwarebestandteile (SBOM)
- KONF.7.11 Einschränkung von Softwarebibliotheken

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.4.3 Softwarebestandteile (SBOM)
- KONF.7.11 Einschränkung von Softwarebibliotheken

Living off the land

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.7.10 Einschränkung der Ausführung

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.7.10 Einschränkung der Ausführung

MFA

Keine Controls gefunden.

Network Access Control

Keine Controls gefunden.

Password Policy

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.6.10 Monitoring von Zugangsdaten
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel

BSI/Grundschutz/Quellkataloge/Kernel

- BER.6.10 Monitoring von Zugangsdaten
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel

Pentest

Keine Controls gefunden.

Phishing

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.1.1 Zertifikatsprüfung
- KONF.13.1 Filtern schädlicher Nachrichten

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.1.1 Zertifikatsprüfung
- KONF.13.1 Filtern schädlicher Nachrichten

Physical Access Control

Keine Controls gefunden.

Privilege Escalation

Keine Controls gefunden.

Privilegierte Rechte

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.21 Notfallzugang
- BER.3.5 Privilegierte Zugangskonten
- BER.5.1 Prinzip der geringsten Berechtigungen
- SENS.10.5 Systemadministration - Internetnutzung

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.21 Notfallzugang
- BER.3.5 Privilegierte Zugangskonten
- BER.5.1 Prinzip der geringsten Berechtigungen
- SENS.10.5 Systemadministration - Internetnutzung

Produktbeschreibung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- KONF.2.8 Abgesicherter und authentisierter Bootprozess

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- KONF.2.8 Abgesicherter und authentisierter Bootprozess

PSTN

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.8.2 Redundante TK-Anbindung
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.8.2 Redundante TK-Anbindung
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen

Recon

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.11.4 Veröffentlichung von Domain-Infomationen

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.11.4 Veröffentlichung von Domain-Infomationen

Replay Attacks

Keine Controls gefunden.

Rogue Access Point

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.1 Netzzugangskontrolle

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.1 Netzzugangskontrolle

Secure Compiling Practices

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.4.2 Bibliotheksquellen
- DEV.4.5 Updates externer Softwarebibliotheken

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.4.2 Bibliotheksquellen
- DEV.4.5 Updates externer Softwarebibliotheken

Security by Default

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.4.8 Default-Zugangsdaten
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.4.8 Default-Zugangsdaten
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default

Security by Design

Keine Controls gefunden.

Separation of Concerns

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.12 Sprungserver
 - ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.4 VoIP-Netz

- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.7 Management-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.7 Management-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6

Session Hijacking

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.14.5 Zeitüberschreitung von Netzverbindungen

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.14.5 Zeitüberschreitung von Netzverbindungen

Shadow IT

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten

BSI/Grundschrift/Quellkataloge/Kernel

- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten

Shared Responsibility Model

BSI/Grundschrift/Anwenderkatalog/Grundschrift++

- BES.1.4 Outsourcing-Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung

BSI/Grundschrift/Quellkataloge/Kernel

- BES.1.4 Outsourcing-Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung

Shoulder Surfing

BSI/Grundschrift/Anwenderkatalog/Grundschrift++

- SENS.9.1 Verarbeitung in der Öffentlichkeit

BSI/Grundschrift/Quellkataloge/Kernel

- SENS.9.1 Verarbeitung in der Öffentlichkeit

VPN

Keine Controls gefunden.

Zero Trust

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne
- ASST.2.2 Inventar der Systeme
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.6.5 Dynamische Zugriffskontrolle im System

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne
- ASST.2.2 Inventar der Systeme
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.6.5 Dynamische Zugriffskontrolle im System

Namespace: target_object_categories

Definitionen zu Zielobjektkategorien (z. B. IT-Systeme

https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/raw/refs/heads/main/Dokumentation/namespaces/target_object_categories.csv

Administrierende

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.13 Lagerung physischer Assets
- BER.3.5 Privilegierte Zugangskonten
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.5 Systemadministration - Internetnutzung
- TEST.2.2 Folgenabschätzung

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.13 Lagerung physischer Assets
- BER.3.5 Privilegierte Zugangskonten
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.5 Systemadministration - Internetnutzung
- TEST.2.2 Folgenabschätzung

Anwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network

- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.7.1 Nicht mehr benötigte Anwendungen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.6 Anomale Nutzung der Anwendung
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.2 Bibliotheksquellen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten

- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.7.2 Zertifikatsmonitoring
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1 Eingabevalidierung
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.8.2 Automatische Updates der Anwendung
- NOT.4.17 Anwendungstest
- NOT.4.3 Sicherung der Anwendung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network

- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.7.1 Nicht mehr benötigte Anwendungen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.6 Anomale Nutzung der Anwendung
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.2 Bibliotheksquellen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten

- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.7.2 Zertifikatsmonitoring
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1 Eingabevalidierung
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.8.2 Automatische Updates der Anwendung
- NOT.4.17 Anwendungstest
- NOT.4.3 Sicherung der Anwendung

Cloud-Dienste

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung

- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.4.8.2 Cloud-Konformität
- BES.7.4.10 Serviceprofil
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- DET.3.1.13 Integration von Cloud-Diensten

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.4.8.2 Cloud-Konformität
- BES.7.4.10 Serviceprofil
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- DET.3.1.13 Integration von Cloud-Diensten

Dateiserver

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.1.9 Journaling
- KONF.12.7 Erweiterte Attribute

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.1.9 Journaling
- KONF.12.7 Erweiterte Attribute

Daten

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen

- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.5 Tainting
- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.4 Nachweis des Zugangs
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3 Geregeltes Löschen oder Vernichten
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Lösungsverfahren
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- DET.3.1.12 Datenverarbeitungen
- DET.3.5 Unbestreitbarkeit
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- NOT.4.14 Offline-Kopie
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.5 Tainting

- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.4 Nachweis des Zugangs
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3 Geregeltes Löschen oder Vernichten
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Löschverfahren
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- DET.3.1.12 Datenverarbeitungen
- DET.3.5 Unbestreitbarkeit
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- NOT.4.14 Offline-Kopie
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation

Datenträgerarchiv

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.8.2 Staub und Schmutz
- GEB.8.4 Überwachung schonender Klimatisierung

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.8.2 Staub und Schmutz
- GEB.8.4 Überwachung schonender Klimatisierung

Dienstleistungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.4.6.1 Authentifizierung des Kunden
- BES.5.1 Kompetenzen
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.5 Nutzungsregelungen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Löschverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.8.5 Treuhand
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.4.1 Dekommissionierung
- DLS.4.1.2 Berechtigungen deaktivieren

BSI/Grundschutz/Quellkataloge/Kernel

- BES.4.6.1 Authentifizierung des Kunden
- BES.5.1 Kompetenzen
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.5 Nutzungsregelungen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.5.9.1 Autorisierung von Änderungen

- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Lösungsverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.8.5 Treuhand
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.4.1 Dekommissionierung
- DLS.4.1.2 Berechtigungen deaktivieren

DNS-Server

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.12.14 DNS-Falschinformationen
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.12.14 DNS-Falschinformationen
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung

E-Mail

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.18 Öffentliche Blocklisten

- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.13.9 Publikation der DMARC-Richtlinie

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.18 Öffentliche Blocklisten
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.13.9 Publikation der DMARC-Richtlinie

Einkäufe

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- BES.2.1 Erfassung des Bedarfes
- BES.2.1.4 Kompatibilität
- BES.2.1.4.1 Kompatibilität der Schnittstellen

- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.5 Security by Design
- BES.4.6 Security by Default
- BES.4.8 Konformitätsnachweise
- BES.4.8.1 Zertifizierung
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.7 Schulung
- BES.7.1 Eingangskontrolle
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.4 Dokumentation der Komponenten
- BES.8.1 Bereithaltung alternativer Lieferanten

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.3 Lieferanten- und Dienstleisterverzeichnis

- BES.1.3.1 Gesamte Lieferkette
- BES.2.1 Erfassung des Bedarfes
- BES.2.1.4 Kompatibilität
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.5 Security by Design
- BES.4.6 Security by Default
- BES.4.8 Konformitätsnachweise
- BES.4.8.1 Zertifizierung
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.7 Schulung
- BES.7.1 Eingangskontrolle
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.4 Dokumentation der Komponenten
- BES.8.1 Bereithaltung alternativer Lieferanten

Endgeräte

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.3 Kiosk-Modus

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.3 Kiosk-Modus

Externe Netzanschlüsse

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.13 Produktdiversität
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS

- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.8.2 Redundante TK-Anbindung
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.13 Produktdiversität
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.8.2 Redundante TK-Anbindung
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen

Fahrzeuge

Keine Controls gefunden.

Faxe

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.13 Sendebericht

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.13 Sendebericht

Führungskräfte

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling

BSI/Grundschutz/Quellkataloge/Kernel

- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling

Gebäude

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.2.2 Dokumentation öffentlicher Bereiche

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.2.2 Dokumentation öffentlicher Bereiche

Hostsysteme

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.7.2 Dedizierte Hardware
- BER.3.20 Dienstkonten
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.15 Ressourcenauslastung von Hostsystemen
- GEB.6.2.1 Hostsysteme
- KONF.9.2 Begrenzung der Rechenleistung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.7.2 Dedizierte Hardware
- BER.3.20 Dienstkonten
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.15 Ressourcenauslastung von Hostsystemen
- GEB.6.2.1 Hostsysteme
- KONF.9.2 Begrenzung der Rechenleistung

Informationen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung

Institutionsleitung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- SENS.11.1 Sensibilisierung der Institutionsleitung

BSI/Grundschutz/Quellkataloge/Kernel

- SENS.11.1 Sensibilisierung der Institutionsleitung

Interne Netzsegmente

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne

Interpersonelle Kommunikation

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.2 Authentizität von Nachrichten

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.2 Authentizität von Nachrichten

IT-Produkte

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.2.1.1 Verwendungszweck
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.6.3 Manipulationsschutz
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- BES.8.4 Individuelle Implementierung kritischer Komponenten

BSI/Grundschutz/Quellkataloge/Kernel

- BES.2.1.1 Verwendungszweck
- BES.2.1.3 Systemvoraussetzungen

- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.6.3 Manipulationsschutz
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- BES.8.4 Individuelle Implementierung kritischer Komponenten

IT-Systeme

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.3 Mikrosegmentierung
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Regelmäßige Wartungen
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.3 Konformitätsprüfung
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.7 IT-System-Zugangskonto
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler

- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.4.10 Host-basierte Köder
- DET.4.2 Automatische Angriffserkennung
- DET.4.9 Manipulations-Checkup
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2 DNS-Anbindung
- KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.5.1 Authentifizierung am System

- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.4.2 Sicherung des Systems

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.3 Mikrosegmentierung
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.5.1 Wartungsbedarf dokumentieren

- ASST.5.2 Geregelter Wartungen
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.3 Konformitätsprüfung
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.7 IT-System-Zugangskonto
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.4.10 Host-basierte Köder
- DET.4.2 Automatische Angriffserkennung
- DET.4.9 Manipulations-Checkup
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge

- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2 DNS-Anbindung
- KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates

- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.4.2 Sicherung des Systems

Mitarbeitende

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.5.6 Wartung durch Externe
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.6.1.2 Neubesetzung
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschuttmitteln

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.5.6 Wartung durch Externe
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.6.1.2 Neubesetzung
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschuttmitteln

Mobiltelefone

Keine Controls gefunden.

Netze

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.2 Gastnetz
 - ARCH.2.2.3 Segmentierung von Servern und Clients
 - ARCH.2.2.4 VoIP-Netz
 - ARCH.2.2.5 OT-Systeme
 - ARCH.2.2.6 Demilitarisierte Zone
 - ARCH.2.2.7 Management-Netz
 - ARCH.2.2.8 Segmentierung von Test und Betrieb
 - ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.5 Netzplan
- ARCH.2.6 Topologieüberwachung
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
 - ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
 - ARCH.5.1.12 Software-definierte Verbindungen
 - ARCH.5.1.2 Netzbasierte Angriffe
 - ARCH.5.1.3 TCP-basierte Angriffe
 - ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.9.1 Dimensionierung der Netzanbindung
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- DET.4.11 Anomalien in Netzen und am Perimeter
 - DET.4.11.2 Netzwerk-Honeypots
 - DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
 - DET.4.12.1 Auslastung des Netzes
- GEB.6.3 Netzkomponenten

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.2 Gastnetz
 - ARCH.2.2.3 Segmentierung von Servern und Clients
 - ARCH.2.2.4 VoIP-Netz
 - ARCH.2.2.5 OT-Systeme
 - ARCH.2.2.6 Demilitarisierte Zone
 - ARCH.2.2.7 Management-Netz
 - ARCH.2.2.8 Segmentierung von Test und Betrieb
 - ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.5 Netzplan
- ARCH.2.6 Topologieüberwachung
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
 - ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
 - ARCH.5.1.12 Software-definierte Verbindungen
 - ARCH.5.1.2 Netzbasierte Angriffe
 - ARCH.5.1.3 TCP-basierte Angriffe
 - ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.9.1 Dimensionierung der Netzanbindung
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- DET.4.11 Anomalien in Netzen und am Perimeter
 - DET.4.11.2 Netzwerk-Honeypots
 - DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
 - DET.4.12.1 Auslastung des Netzes
- GEB.6.3 Netzkomponenten

Nutzende

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- BER.6.1 Passwortmanager
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.2 Meldewege
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen

- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.3 Verwahrung außer Haus
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.6 Mitnahme ins Ausland
- SENS.9.7 Reise- und Sicherheitshinweise

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- BER.6.1 Passwortmanager
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.2 Meldewege
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien

- SENS.4.1 Personengebundene Authentisierungsmittel
 - SENS.4.1.1 Verdeckte Eingabe
 - SENS.4.1.2 Untersagung von Passwort Recycling
 - SENS.4.1.3 Wahl von Passwörtern
 - SENS.4.1.4 Passwörter nur im Passwortmanager
 - SENS.4.1.5 Biometrische Authentifikation
 - SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.3 Verwahrung außer Haus
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.6 Mitnahme ins Ausland
- SENS.9.7 Reise- und Sicherheitshinweise

Office-Anwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.1.11 Aktive Dateiinhalte

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.1.11 Aktive Dateiinhalte

Outsourcing

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.4 Outsourcing-Strategie
- BES.1.4.1 Freigabe der Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.4.5.2 Mandantentrennung
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.5.11 Recht auf Audit
- BES.5.13.1 Datenbereitstellung
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.9 Auslagerungsregister
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.4 Anhörung
- DLS.3.6 Portabilität
- DLS.4.1.1 Unabhängigkeit
- NOT.4.13 Datensouveränität

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.4 Outsourcing-Strategie
- BES.1.4.1 Freigabe der Strategie
- BES.2.1.2 Geschäftsprozessprofile

- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.4.5.2 Mandamententrennung
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.5.11 Recht auf Audit
- BES.5.13.1 Datenbereitstellung
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4.11 Dokumentierte Mandamententrennung
- BES.7.4.9 Auslagerungsregister
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.4 Anhörung
- DLS.3.6 Portabilität
- DLS.4.1.1 Unabhängigkeit
- NOT.4.13 Datensouveränität

Räume

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.19 Unautorisierte Sendeanlagen
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.19 Unautorisierte Sendeanlagen
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock

Räume für technische Infrastruktur

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung

Serverräume

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.1.2 Klimamessung
- GEB.10.2.7 Brandunterdrückung
- GEB.6.4 Normgerechte Rechenzentren

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.1.2 Klimamessung
- GEB.10.2.7 Brandunterdrückung
- GEB.6.4 Normgerechte Rechenzentren

Standorte

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.7.5 Vernichtungseinrichtungen
- GEB.1.3 Autorisierung von Standorten
- GEB.1.3.1 Abnahme von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2 Brandschutz
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.4.1 Niederohmigkeit
- GEB.2.1 Installation von Perimetern
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.3.3 Besucheranmeldung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang

- GEB.7.1 Schlüsselbeauftragte
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.7.3 Schlüsselaudit
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.8.1.1 Archiv
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.7.5 Vernichtungseinrichtungen
- GEB.1.3 Autorisierung von Standorten
- GEB.1.3.1 Abnahme von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2 Brandschutz
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.4.1 Niederohmigkeit
- GEB.2.1 Installation von Perimetern
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung

- GEB.3.1 Überwachung von Zutrittspunkten
 - GEB.3.1.1 Videoüberwachung
 - GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.3 Authentifizierung vor Zutritt
 - GEB.3.3.1 Zugangskontrollanlage
 - GEB.3.3.2 Dokumentation von Zutritten
 - GEB.3.3.3 Besucheranmeldung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.7.3 Schlüsselaudit
- GEB.8.1 Gesonderte Aufbewahrung
 - GEB.8.1.1 Archiv
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
 - GEB.9.1.1 Vorausschauende Lastanalyse
 - GEB.9.1.2 Dedizierte Elektrounterverteilung
 - GEB.9.1.3 Redundante Stromversorgung
 - GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
 - GEB.9.5.1 Physisch geschützte Verlegung

TK-Anwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.11.1.1 Authentifizierung von geplanten Konversationen

- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.12 Verbindungsprotokoll

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.12 Verbindungsprotokoll

Verzeichnisdienste

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.22 Notfallzugang Verzeichnisdienst
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- KONF.12.1.8 Duplikate im Verzeichnisbaum

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.22 Notfallzugang Verzeichnisdienst
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- KONF.12.1.8 Duplikate im Verzeichnisbaum

Virtualisierungslösungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.7.3 Entwicklungs- und Testumgebungen
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.6.16 Datenaustausch in der Virtualisierung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.7.3 Entwicklungs- und Testumgebungen
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.6.16 Datenaustausch in der Virtualisierung

VK-Anwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.11.2 Warteraum
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.6.12 Konferenzmoderation

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.11.2 Warteraum
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.6.12 Konferenzmoderation

Webanwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.10 Cookie-Attribute

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.10 Cookie-Attribute

Webbrowser

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.6 Browser-Historie
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.6 Browser-Historie
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung

Webserver

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.7 Auslaufen von Domains

- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code

WLANS

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.3.1 Netzabdeckung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.3.1 Netzabdeckung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung